



Report on Nuance Communications, Inc.'s Description of Its Nuance Healthcare Systems and on the Suitability of the Design and Operating Effectiveness of Its Controls Relevant to Security and Confidentiality Throughout the Period May 1, 2025 to April 30, 2026

SOC 2® - SOC for Service Organizations: Trust Services Criteria



Disclosure Statement:

This document contains confidential and proprietary information of both Nuance Communications, Inc. and Coalfire Controls, LLC.

© 2026 Coalfire Controls, LLC. All rights reserved.

Table of Contents

Section 1

Independent Service Auditor's Report 3

Section 2

Assertion of Nuance Communications, Inc. Management..... 8

Section 3

Nuance Communications, Inc.'s Description of Its Nuance Healthcare Systems Throughout the
Period May 1, 2025 to April 30, 2026 11

Section 4

Trust Services Criteria, Related Controls and Tests of Controls Relevant to the Security and
Confidentiality Categories 55

Section 1

Independent Service Auditor's Report

Independent Service Auditor's Report

To: Nuance Communications, Inc. ("Nuance")

Scope

We have examined Nuance's accompanying description found in Section 3 titled "Nuance Communications, Inc.'s Description of Its Nuance Healthcare Systems Throughout the Period May 1, 2025 to April 30, 2026" (description) based on the criteria for a description of a service organization's system in DC Section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance—2022)*, in AICPA, *Description Criteria*, (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period May 1, 2025 to April 30, 2026, to provide reasonable assurance that Nuance's service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality (applicable trust services criteria) set forth in TSP Section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)*, in AICPA, *Trust Services Criteria*.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Nuance, to achieve Nuance's service commitments and system requirements based on the applicable trust services criteria. The description presents Nuance's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Nuance's controls. Our examination did not include such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such controls.

Nuance uses a subservice organization to provide data center colocation services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Nuance, to achieve Nuance's service commitments and system requirements based on the applicable trust services criteria. The description presents Nuance's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Nuance's controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

Nuance uses Microsoft Azure to provide a wide variety of services including HR functions and vendor management services. The description indicates that complementary corporate-level controls of Microsoft Azure that are suitably designed and operating effectively are necessary, along with controls at Nuance, to achieve Nuance's service commitments and system requirements based on the applicable trust services criteria. The description presents Nuance's controls, the applicable trust services criteria, and the types of complementary corporate-level controls assumed in the design of Nuance's controls. The description does not disclose the actual controls at Microsoft Azure. Our examination did not include the services provided by Microsoft Azure, and we have not evaluated the suitability of the design or operating effectiveness of such complementary corporate-level controls.

Service Organization's Responsibilities

Nuance is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that

Nuance's service commitments and system requirements were achieved. In Section 2, Nuance has provided the accompanying assertion titled "Assertion of Nuance Communications, Inc. Management" (assertion) about the description and the suitability of design and operating effectiveness of controls stated therein. Nuance is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves—

- Obtaining an understanding of the system and the service organization's service commitments and system requirements.
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria.
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Evaluating the overall presentation of the description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual report users may consider important to meet their informational needs. There are inherent limitations in any system of internal control, including the

possibility of human error and the circumvention of controls. Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls we tested and the nature, timing, and results of those tests are listed in Section 4, "Trust Services Criteria, Related Controls and Tests of Controls Relevant to the Security and Confidentiality Categories" of this report.

Opinion

In our opinion, in all material respects—

- a. The description presents the Nuance Healthcare Systems that were designed and implemented throughout the period May 1, 2025 to April 30, 2026, in accordance with the description criteria.
- b. The controls stated in the description were suitably designed throughout the period May 1, 2025 to April 30, 2026, to provide reasonable assurance that Nuance's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if Microsoft Azure, the subservice organization and user entities applied the complementary controls assumed in the design of Nuance's controls throughout that period.
- c. The controls stated in the description operated effectively throughout the period May 1, 2025 to April 30, 2026, to provide reasonable assurance that Nuance's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary corporate-level controls, complementary subservice organization controls and complementary user entity controls assumed in the design of Nuance's controls operated effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of Nuance, user entities of the Nuance Healthcare Systems during some or all of the period May 1, 2025 to April 30, 2026, business partners of Nuance subject to risks arising from interactions with the Nuance Healthcare Systems, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization.
- How the service organization's system interacts with user entities, business partners, the subservice organization, and other parties.
- Internal control and its limitations.
- Complementary user entity controls, complementary corporate-level controls and complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements.

- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services.
- The applicable trust services criteria.
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks.

This report should only be used in conjunction with the service organization controls report covering the description of Microsoft Azure addressing corporate functions.

This report is not intended to be, and should not be, used by anyone other than these specified parties.

If a report recipient is not a specified party as defined above and has obtained this report, or has access to it, use of this report is the non-specified user's sole responsibility and at the non-specified user's sole and exclusive risk. Non-specified users may not rely on this report and do not acquire any rights against Coalfire Controls, LLC as a result of such access. Further, Coalfire Controls, LLC does not assume any duties or obligations to any non-specified user who obtains this report and/or has access to it.

Coalfire Controls LLC

Louisville, Colorado
June 25, 2026

Section 2

Assertion of Nuance Communications, Inc. Management



Partner Security Engineering Manager
Nuance Communications (a Microsoft company)
15 Wayside Road
Burlington, MA 01803

Assertion of Nuance Communications, Inc. (“Nuance”) Management

We have prepared the accompanying description titled “Nuance Communications, Inc.’s Description of Its Nuance Healthcare Systems Throughout the Period May 1, 2025 to April 30, 2026” (description) based on the criteria for a description of a service organization’s system in DC Section 200, *2018 Description Criteria for a Description of a Service Organization’s System in a SOC 2® Report (With Revised Implementation Guidance—2022)*, in AICPA, *Description Criteria* (description criteria). The description is intended to provide report users with information about the Nuance Healthcare Systems that may be useful when assessing the risks arising from interactions with Nuance’s system, particularly information about system controls that Nuance has designed, implemented and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality (applicable trust services criteria) set forth in TSP Section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)*, in AICPA, *Trust Services Criteria*.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Nuance, to achieve Nuance’s service commitments and system requirements based on the applicable trust services criteria. The description presents Nuance’s controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Nuance’s controls.

Nuance uses a subservice organization for data center colocation services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Nuance, to achieve Nuance’s service commitments and system requirements based on the applicable trust services criteria. The description presents Nuance’s controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Nuance’s controls. The description does not disclose the actual controls at the subservice organization.

Nuance uses Microsoft Azure for a wide variety of services including HR functions and vendor management services. The description indicates that complementary corporate-level controls of Microsoft Azure that are suitably designed and operating effectively are necessary, along with controls at Nuance, to achieve Nuance’s service commitments and system requirements based on the applicable trust services criteria. The description presents Nuance’s controls, the applicable trust services criteria, and the types of complementary corporate-level controls assumed in the design of Nuance’s controls. The description does not disclose the actual controls at Microsoft Azure.

We confirm, to the best of our knowledge and belief, that:

- a. The description presents the Nuance Healthcare Systems that were designed and implemented throughout the period May 1, 2025 to April 30, 2026, in accordance with the description criteria.

- b. The controls stated in the description were suitably designed throughout the period May 1, 2025 to April 30, 2026, to provide reasonable assurance that Nuance's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if Microsoft Azure, the subservice organization and user entities applied the complementary controls assumed in the design of Nuance's controls throughout that period.
- c. The controls stated in the description operated effectively throughout the period May 1, 2025 to April 30, 2026, to provide reasonable assurance that Nuance's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary corporate-level controls, complementary subservice organization controls and complementary user entity controls assumed in the design of Nuance's controls operated effectively throughout that period.

Nuance Communications, Inc.

Section 3

Nuance Communications, Inc.'s Description of Its Nuance Healthcare Systems Throughout the Period May 1, 2025 to April 30, 2026

Type of Services Provided

Nuance Communications, Inc. (“Nuance” or “the Company”), a Microsoft company, is a provider of voice and language solutions for businesses and consumers around the world. Physicians and healthcare facilities worldwide leverage Nuance’s voice-enabled clinical documentation and analytics solutions to support the physician in any clinical workflow and on any device.

The scope of this assessment are the following hosted healthcare products (collectively, “Nuance Healthcare Systems”):

1. Clintegrity clinical documentation improvement (CDI) and computer-assisted physician documentation (CAPD) products including:
 - a. Clinical Language Understanding (CLU)
 - b. CDE One
1. PowerShare Image Sharing (“PowerShare”)
2. mPower Clinical Analytics (“mPower”)
3. Precision Imaging Network (PIN) (AKA AI Marketplace)
4. PowerScribe One Essentials / PowerScribe One 2023 (On-prem)
 - a. PowerScribe One Smart Impressions
5. Dragon Professional Anywhere (DPA)
6. Dragon Ambient eXperience (DAX) / DAX Copilot

The subsections below provide more detail about each product or category of product.

CDI and CAPD Products

These products include the Nuance Clinical Language Understanding (CLU) framework.

- Dragon Medical Advisor (all content types)
- Nuance CDE One/Nuance Encounter Prioritization
- CLU for PowerScribe One/Assure

CAPD is designed to help physicians include details necessary to support International Classification of Diseases (ICD)-10 in documentation. Nuance’s CAPD solutions are designed to support coding and provide automated, clinically appropriate guidance and clarifications to physicians at natural points during their workflow.

As an automated extension to the CDI program, Nuance’s solutions help physicians document the details required for communication of care, reimbursement, and quality reporting in their preferred workflow. Utilizing CLU, these products analyze the content of a dictated note in “real time” to identify gaps and ambiguities in the note and provide the physician relevant suggestions to improve clinical documentation, focusing on communication about the patient and enabling physicians to indicate details relevant to ongoing patient care and communication with other caregivers. Nuance CDI Specialist teams can review the automated interaction with the physician, allowing them to focus their efforts on more complex cases and continued quality improvement initiatives.

The Nuance CDE One solution is a comprehensive portfolio of cloud-based documentation guidance technologies and services that enable focus on quality while improving clinical and revenue integrity. Our clinically focused program allows organizations to take advantage of AI-powered physician guidance, encounter prioritization, workflow management, clinical and financial analytics and CDI best practice to meet organizational goals.

PowerShare Image Sharing

PowerShare is a cloud-based medical image sharing network that enables healthcare providers and patients to securely access, view, and exchange diagnostic images and related clinical content. Built on an established network of connected hospitals, imaging centers, and healthcare organizations, PowerShare provides on-demand access to imaging studies as patients move across facilities, health systems, and care settings.

Using a hub-and-spoke exchange model, organizations can receive, manage, and share imaging content through the PowerShare cloud with referring providers, specialists, patients, and other authorized recipients. By streamlining secure image exchange, PowerShare helps reduce duplicate exams, accelerate clinical decision-making, improve care coordination, and support continuity of care.

The following diagram illustrates high level PowerShare services and example data flows.

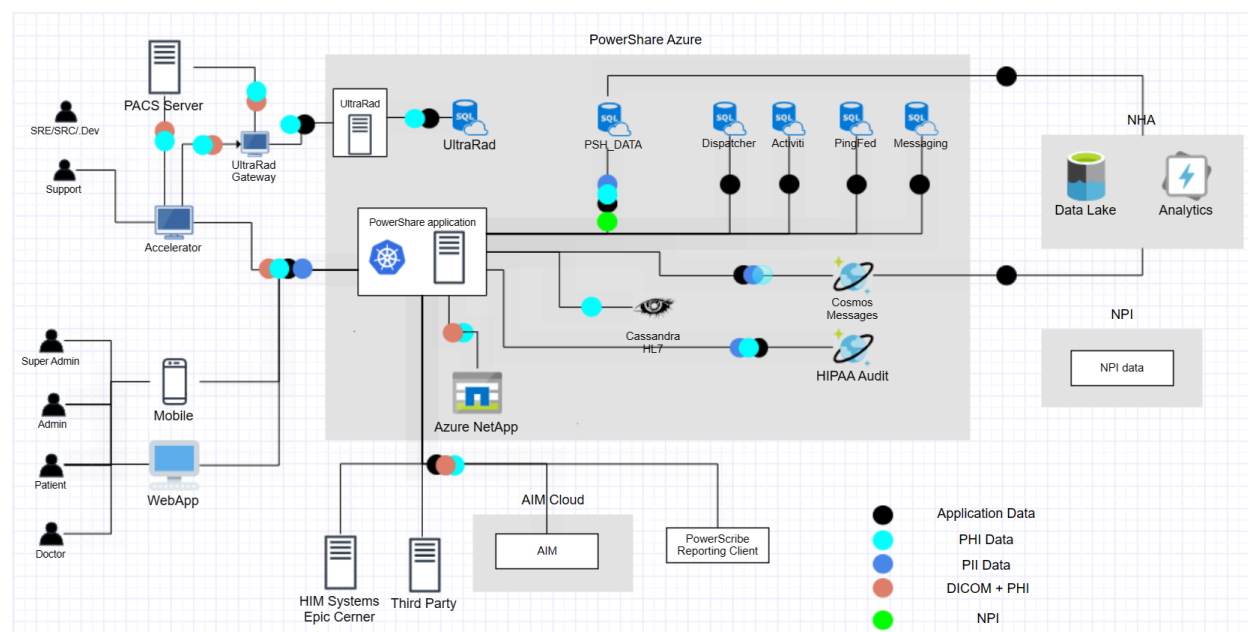


Figure 1: PowerShare Services and Data Flows

Most clients use the product remotely through a web-based application.

mPower

mPower offers customizable reporting tools and provides access to a single, hosted application that provides data, helping make it easier to monitor, understand, and improve clinical and operational performance.

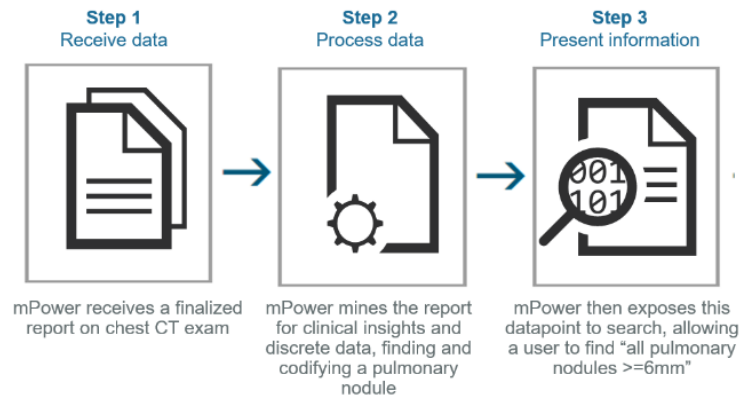


Figure 2: mPower Workflow

mPower allows practice leaders, clinicians, researchers, and educators to search Nuance's radiology reporting database for key business and clinical data. Users can access a holistic view of all prior radiology reports and corresponding data elements through use of voice commands or keystrokes. In addition, proprietary data-mining techniques and Natural Language Processing (NLP) allow for advanced searches to support research and quality improvement initiatives as well as to provide business and quality analytics.

mPower is hosted within the Microsoft Azure US East region. Nuance follows industry-standard frameworks such as the Microsoft Security Development Lifecycle (Microsoft SDL) and the Building Security in Maturity Model (BSIMM). The Nuance secure software development life cycle (SDLC) program provides secure design and implementation governance, potential identification and remediation of any security issues before new products are released, and rapid response by development teams should there be security issues discovered after release.

Precision Imaging Network (PIN)

PIN provides an open marketplace for subscribers to purchase FDA-cleared artificial intelligence (AI) applications from a variety of developers and integrate that intelligence into radiology workflows, allowing radiologists to review, try, validate, and buy AI models. PIN allows AI developers to connect their AI solutions to radiologists across the healthcare facilities that use Nuance PowerShare Image Sharing. PIN gives radiologists a one-stop shop to make AI beneficial.

The participating radiology department or practice controls the workflow between PIN and the reporting process, determining which studies they wish to have processed by AI models. The facility Digital Imaging and Communications in Medicine (DICOM) routes these studies to an on-premise PowerShare Accelerator Gateway, which forwards the studies to the cloud for processing. Nuance PowerShare Image Sharing provides the cloud-based infrastructure for this information exchange, and PowerShare notifies PIN when new studies arrive. The core PowerShare components necessary for this exchange are required and included with an AI Marketplace subscription.



Based on the medical facility's AI subscriptions, PIN executes rules to determine which studies should be processed by which AI services. These services may be cloud-hosted within the PIN cloud or self-hosted using the AI developer's facilities.

- Nuance cloud-hosted services: Nuance controls the execution of the AI services, and no data leaves Nuance systems, eliminating the need for a Business Associate Agreement (BAA) or a security review with these AI partners.
- Self-hosted services: Studies sent to self-hosted services are encrypted during transit and sent to the AI developer for processing, and each facility must sign a BAA with each AI developer they wish to subscribe to.

Reporting tools can report radiologist feedback back to PIN. Feedback is in the form of an observation being accepted, rejected, or modified. This feedback is tracked for quality, but also controls whether results are pushed to the Picture Archiving and Communication System (PACS).

When optionally configured, DICOM images generated during AI processing or created/modified during report generation, can be pushed to the PACS. There are three options when pushing to PACS: (1) Don't do it, (2) push as soon as results are available, and (3) wait for the report to be signed and only send if all the results are accepted.

PowerScribe One

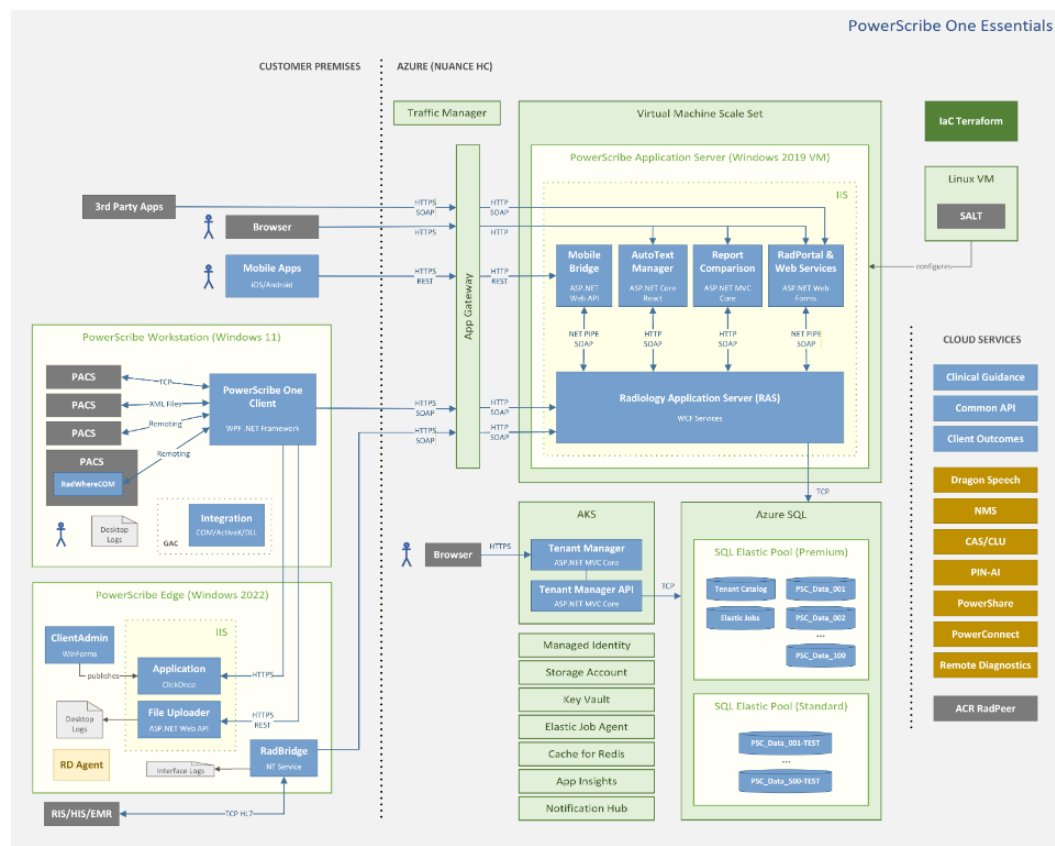
PowerScribe One uses continuous learning and context-aware language understanding technology to convert unstructured text into structured data to expand interoperability and provide information to data-driven applications. It integrates access to AI algorithms within the radiology workflow, giving radiologists tools to help improve efficiency and throughput, increase diagnostic accuracy and specificity, and ensure consistent, evidence-based follow-up recommendations.

PowerScribe One leverages AI-driven natural language understanding, image characterization, speech recognition, and intelligent exchange of structured data to enable radiologists to: (1) capture and apply structured data to aid in the creation of accurate, clinically appropriate, and consistent diagnostic reports, (2) share clinically relevant data between Electronic Health Record (EHRs), PACS, and other systems, (3) dynamically populate reports with content from integrated systems, (4) integrate AI image characterization directly into the reporting workflow via PIN, and (5) make standardized reporting initiatives easier to launch, promote, and adopt.

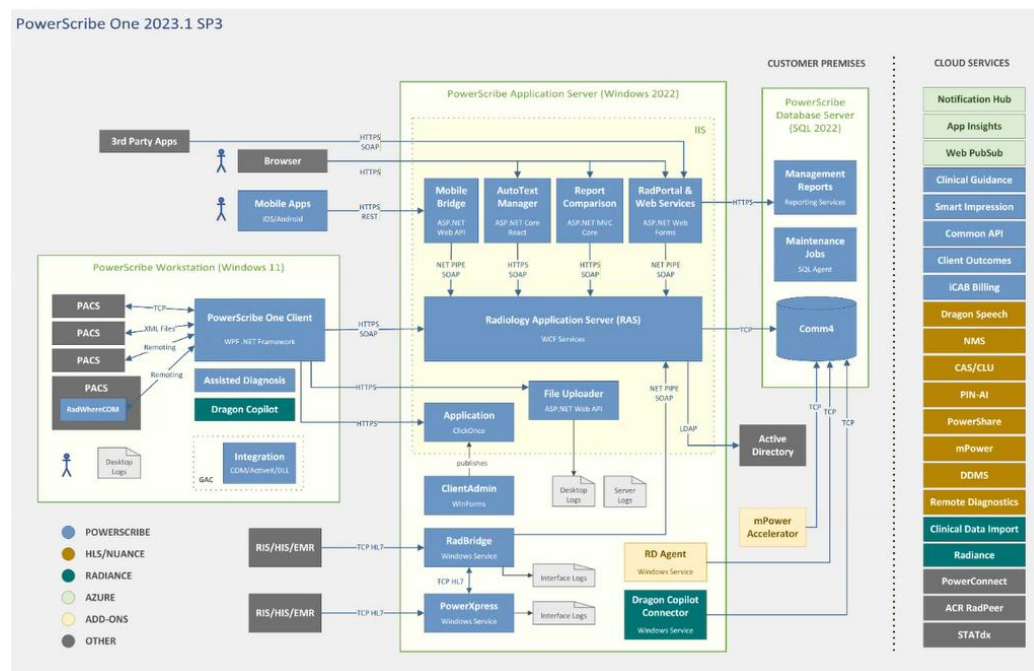
PowerScribe One Smart Impression

PowerScribe One Smart Impression is a functionality invoked by radiologist from PowerScribe One client. It invokes generative AI to automatically create draft impressions to help save time, reduce workload-related stress, and lower cognitive load. The AI-powered model uses radiologist findings, order information, and other relevant data to generate an impression draft in the style of the dictating radiologist helping to drive improved efficiency and increase radiologist satisfaction. The AI model may generate incorrect content, thus the radiologist is required to review the report prior to signature.

The following diagrams illustrate diagrams and sample dataflows of high level systems for PowerScribe One Essentials:



PowerScribe One 2023.1 SP3



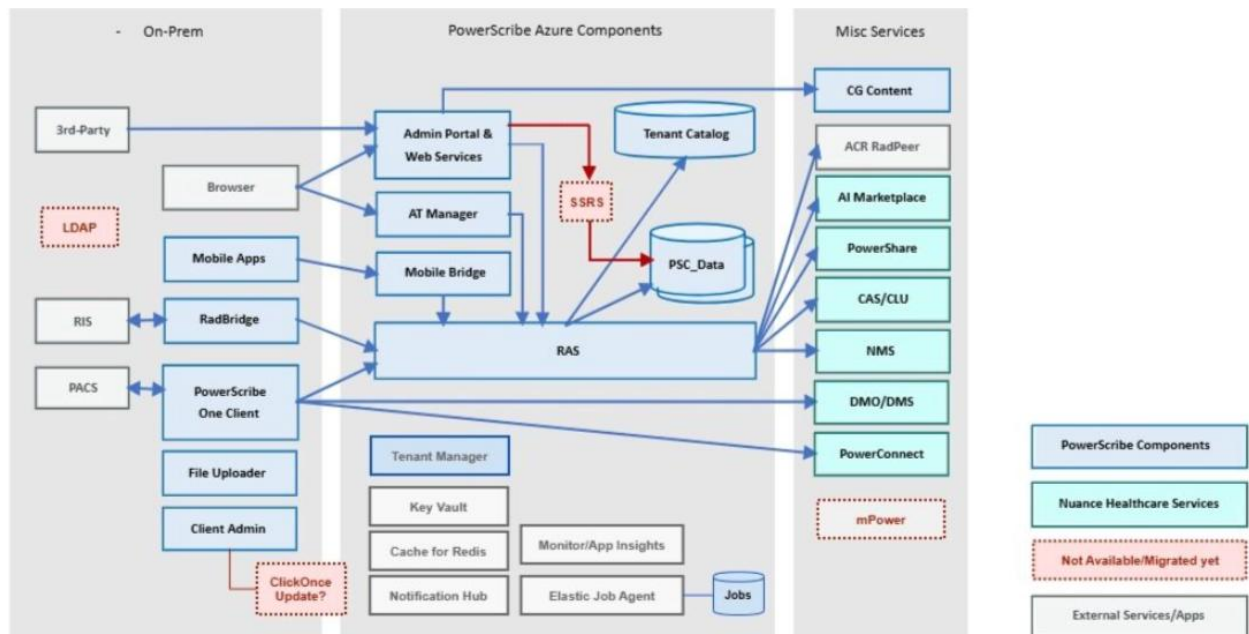
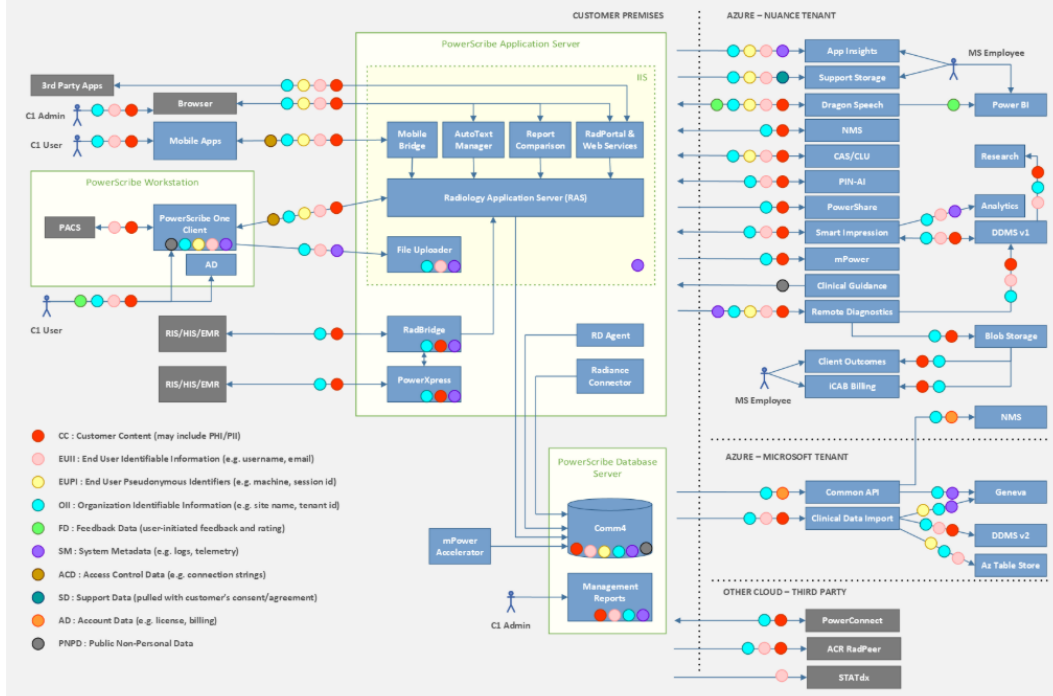


Figure 4: PowerScribe One Essentials Sample Dataflow

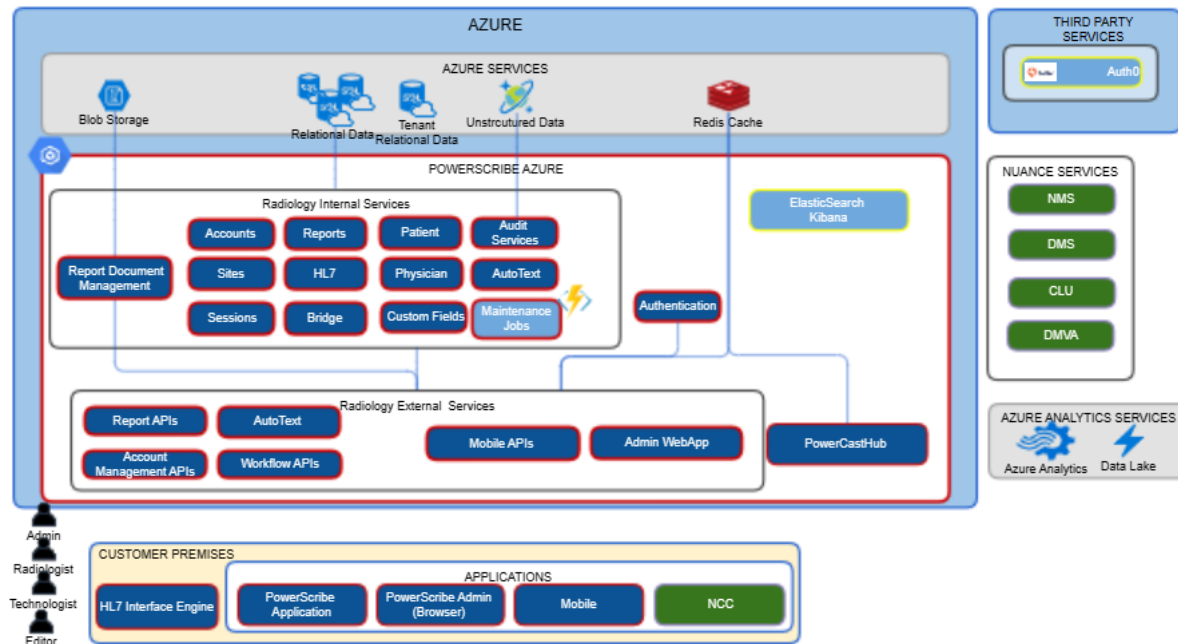
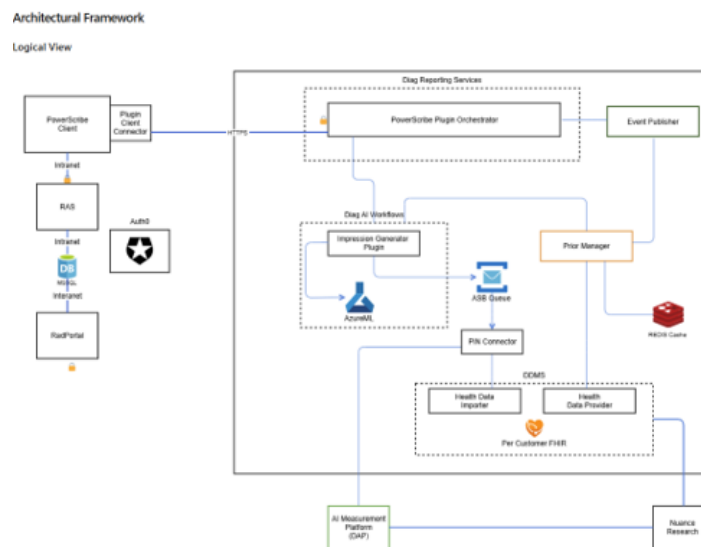


Figure 5: PowerScribe

Smart Impressions



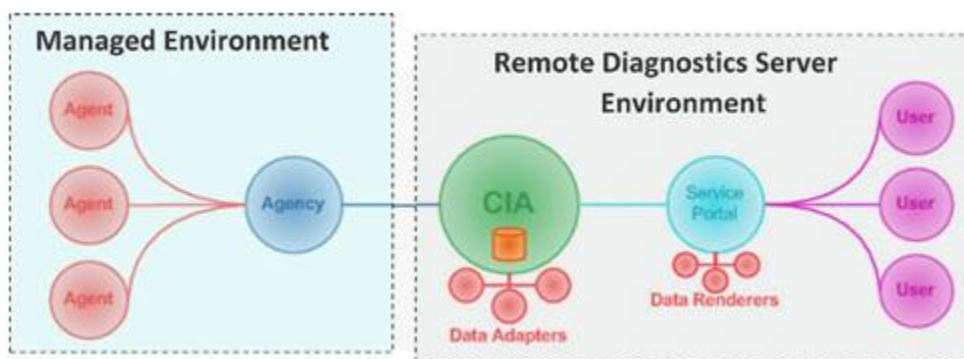
The Remote Diagnostics solution is a distributed monitoring and diagnostics platform designed to support the health, performance, and reliability of mission-critical healthcare systems. It operates through an extensible architecture consisting of agents, agencies, and a centralized server, enabling proactive monitoring, diagnostics, and support activities across customer environments.

The architecture follows a secure, outbound-only communication model, where all communications are initiated by the on-premises Agency component to the Central Server using industry-standard 256-bit SSL encryption. The Central Server cannot directly initiate connections to customer systems, reducing exposure risk and aligning with secure network design principles.

Remote Diagnostics is designed to monitor server operating systems, applications, infrastructure resources, and service availability. Specialized agents perform targeted functions such as event monitoring, software updates, service health checks, log monitoring, database monitoring, and infrastructure resource tracking. These agents report status, alerts, and diagnostic data back through the Agency to the Central Server for centralized visibility and response.

The Central Server acts as a central repository and web service host for alerts and diagnostic data received from customer environments. It supports trend analysis, issue identification, and operational support workflows via an administrative service portal. This distributed model enables scalable monitoring while allowing application-specific diagnostics tailored to customer and product needs.

From a compliance perspective, the solution is designed to support healthcare customers' HIPAA Security Rule obligations. The Remote Diagnostics platform does not collect or store Protected Health Information (PHI), and all transmitted data is limited to system, application, and infrastructure telemetry required for operational monitoring and support.



Dragon Professional Anywhere

DPA is a secure, cloud-based speech recognition solution that allows individuals to create documentation using voice.

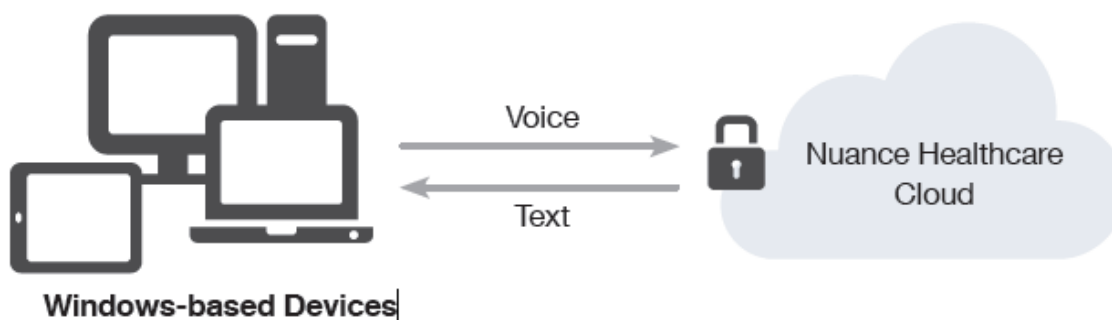


Figure 6: Dragon Professional Anywhere

DPA provides cloud-based speech recognition across an existing infrastructure of Windows-based devices, including virtualized and remote-access PCs. The lightweight Windows client application provides a secure connection to the Nuance cloud. It delivers cross-channel access to user voice profiles, real-time speech-to-text and up-to-date dictionary, terms, phrases, and formatting rules. Additional features include zero voice profile training, specialty-specific language models, automated user accent detection and gain control, custom vocabularies and templates, and voice-based correction.

Users open the application from the Windows Start menu, place the cursor where they want speech-recognized text to appear, and start dictating into any Windows-based application (e.g., Microsoft Outlook and Microsoft Word). Standard preferred dictation hardware, such as the PowerMic III, is plug-and-play, but other hardware is also supported.

Dragon Ambient eXperience

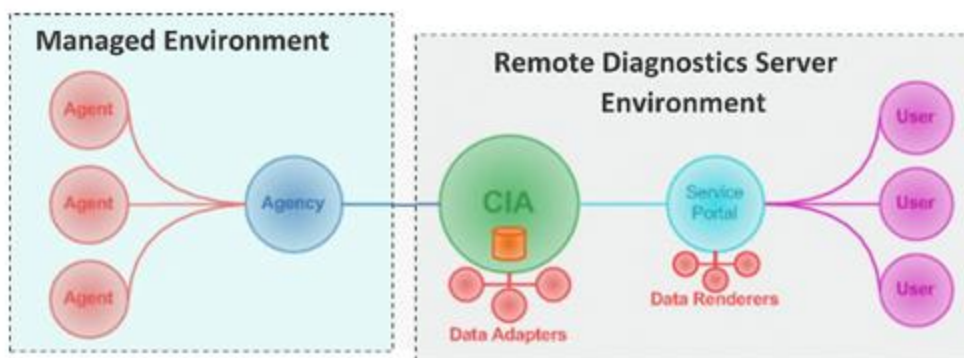
DAX is a mobile application and virtual medical scribing service. Healthcare providers record audio of patient encounters using the mobile application, and scribes listen to the encounters, write medical documentation, and enter the data in the EHRs for healthcare providers. The provider workflow utilizing DAX is as follows:

- A physician uses the DAX application on an iOS device to record patient encounters
- Encrypted recordings are uploaded to a server in compliance with the Health Insurance Portability and Accountability Act (HIPAA)
- A dedicated scribe listens to audio-recorded patient encounters from a secure, off-site location and completes documentation directly in the EHR. Medical scribes are trained to synthesize salient information from the recorded encounter into a high-quality medical chart. Scribes can also transcribe dictation in special cases when required by the provider's workflow
- Healthcare providers review and approve the completed record(s)

The audio file is recorded on the mobile device by the provider and is encrypted. Each recording is uploaded immediately to the DAX Microsoft Azure-hosted environment and is then immediately and automatically deleted from the mobile device. The recording file is then sent to the Nuance AI technology pipeline for processing. The Nuance AI technology pipeline converts the recording into a draft note. The documentation specialist reviews the note for quality and then enters the note directly into the customer's EHR using remote login/credentials.

DAX Copilot

DAX Copilot, formerly DAX Express, combines conversational and ambient AI with generative AI into a mobile application that integrates directly with physicians' existing workflows. This cloud-based application securely captures and automatically converts multi-party conversations into specialty-specific, structured, clinical summaries immediately after a patient encounter. Using voice instructions, clinicians can access a full suite of customizations, templates, and shortcuts that allow them to personalize their notes using Dragon Medical One's advanced speech capabilities and EHR workflows.



Principal Service Commitments and System Requirements

Commitments are declarations made by management to customers regarding the performance of the Nuance Healthcare Systems. Commitments are communicated within Master Hosted Service Agreements, Hosted Services Orders, and the Privacy Statement.

System requirements are specifications regarding how the Nuance Healthcare Systems should function to meet the Company's principal commitments to user entities. System requirements are specified in the Company's policies and procedures.

The Company's principal service commitments and system requirements related to the Nuance Healthcare Systems include the following:

Trust Services Category	Service Commitments	System Requirements
Security	- Nuance will provide 24/7 monitoring and maintenance 365 days a year through the Service Reliability Center (SRC). - Nuance will perform platform maintenance (scheduled and emergency) and upgrades via SRC personnel. - Nuance will provide incident management support and track incidents in a web-based ticket tracking system. - Nuance will notify a specific customer of any incident that affects their data. - Nuance will notify customers of any known events based on the applicable severity level.	- Logical access standards - Physical access standards - Employee provisioning and deprovisioning standards - Access reviews - Encryption standards - Intrusion detection and prevention standards - Risk and vulnerability management standards - Configuration management - Incident handling standards - Change management standards - Vendor management - Security groups - Firewalls

Trust Services Category	Service Commitments	System Requirements
Confidentiality	- Nuance will only permit the disclosure of confidential information if such disclosure is in response to an order of a court or other governmental body or otherwise required by law. - Nuance will not use confidential information for purposes other than in the regular course of providing services. - Nuance will return or destroy all confidential information in tangible form upon written request or upon the expiration or termination of the service. - Nuance will use the same degree of care, but no less than a reasonable degree of care, to prevent the unauthorized use, disclosure, or publication of confidential information to third parties as it uses to protect its own confidential information.	- Data classification - Retention and destruction standards - Data handling standards - Internal confidentiality standards - Information sharing standards

The Components of the System Used to Provide the Services

The boundaries of the Nuance Healthcare Systems are the specific aspects of the Company's infrastructure, software, people, procedures, and data necessary to provide its cloud services and that directly support the services provided to customers. Any customer-hosted or self-hosted infrastructure, software, people, procedures, and data or any infrastructure, software, people, procedures, and data that indirectly support the services provided to customers are not included within the boundaries of the Nuance Healthcare Systems.

The components that directly support the services provided to customers are described in the subsections below.

Infrastructure and Software

The Company utilizes Microsoft Azure to provide the resources to host the Nuance Healthcare Systems. The Company leverages the experience and resources of Microsoft Azure to scale quickly and securely as necessary to meet current and future demand. However, the Company is responsible for designing and configuring the Nuance Healthcare Systems architecture within Microsoft Azure to ensure the security and resiliency requirements are met.

The in-scope hosted infrastructure consist of the supporting tool, as shown below:

Data Hosting	
Provider	Business Function
Microsoft Azure	Data center facility

Software consists of the programs and software that support the Nuance Healthcare Systems (operating systems [OSs], middleware, and utilities).

The subsections below detail the infrastructure requirements as well as provide information on the software and ancillary software used to build, support, secure, maintain, and monitor the Nuance Healthcare Systems.

CDI and CAPD Infrastructure and Software

Documents to be processed by CDI and CAPD are submitted from the customer premise application interface via authenticated, encrypted connections to CDI and CAPD hosted services for processing and are returned to the customer. CAPD and CLU Software Development Kits (SDK) support interactive and rapid response customer workflows. CDI and CAPD are asynchronous workflows. An application overview is provided in the following diagram.

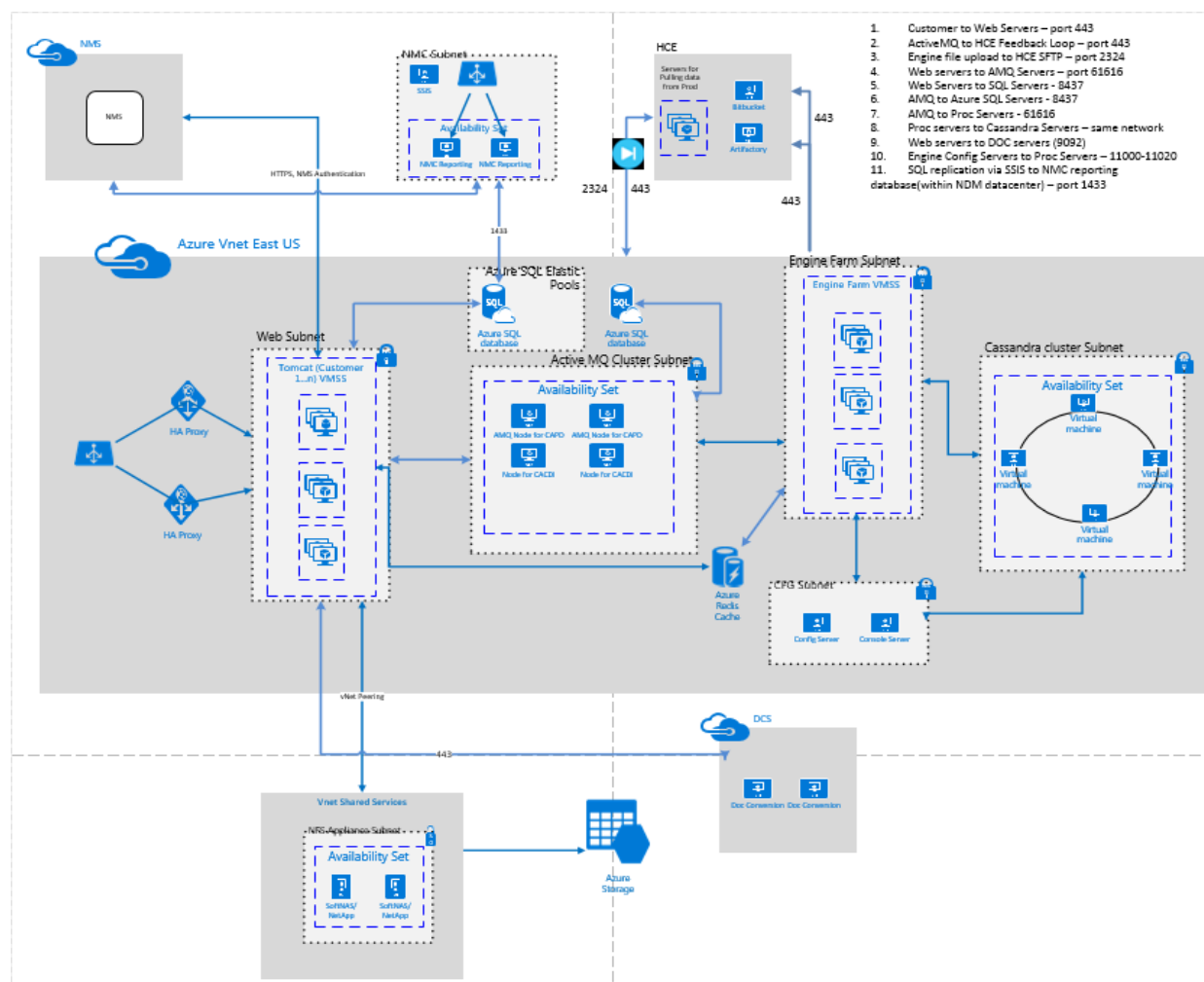


Figure 7: CDI and CAPD

- Transient NLP storage layer comprised of Apache Cassandra distributed database management with data synchronized and replicated across a minimum of three nodes
- Other data services provided by Microsoft Azure SQL Database

- Interface with Nuance Management Server (NMS) hosted at Microsoft Azure sites, for authentication and license validation
- Interface with Nuance Conversion Service (NCS) for conversion to XHTML from PDF and RTF

CDE One Infrastructure and Software

CDE One uses architecture deployed on the Microsoft Azure cloud as depicted below.

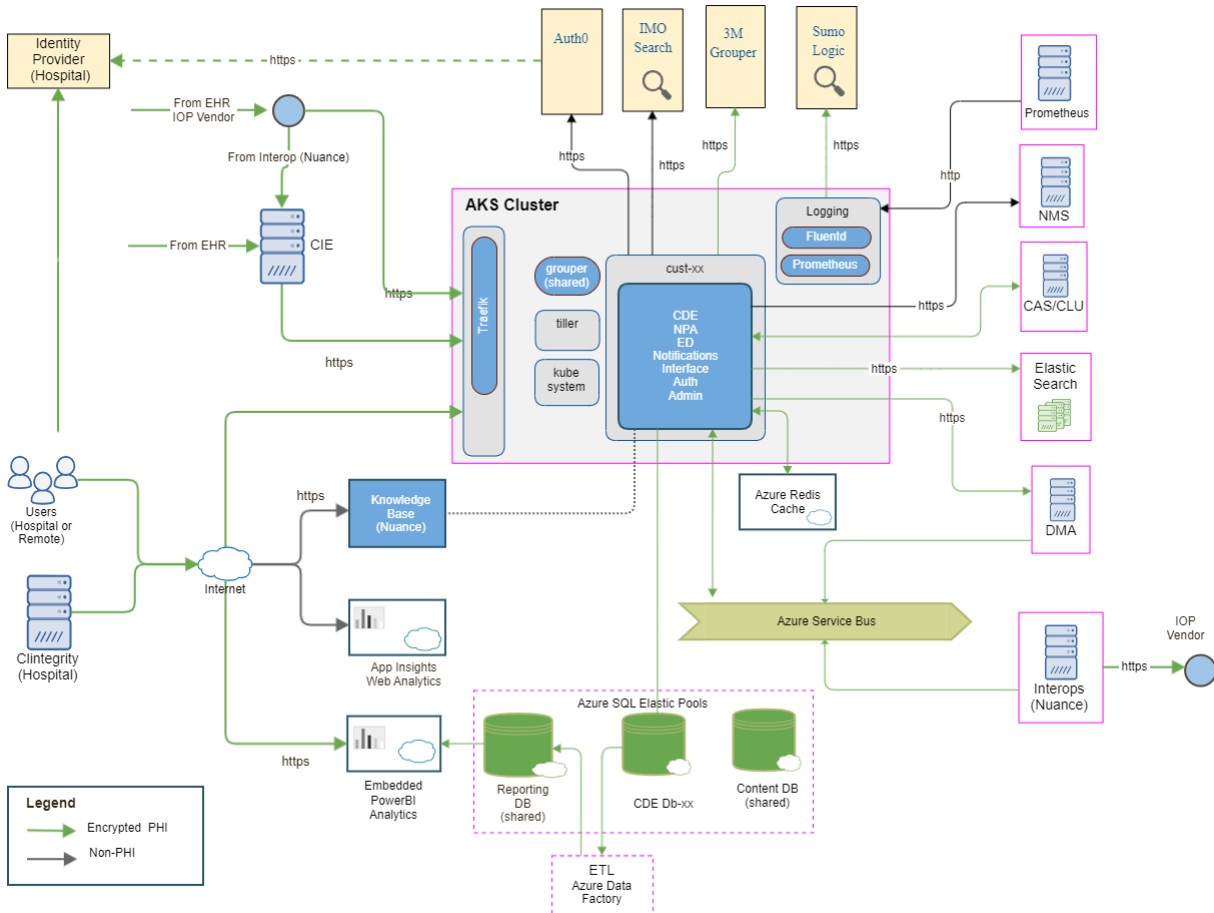


Figure 8: CDE One Architecture

PowerShare Infrastructure and Software

PowerShare is currently hosted at Microsoft Azure East US and West US data centers. Its assets include, but are not limited to, the following Microsoft Azure suite tools:

- Microsoft Azure Virtual Machines
- Microsoft Azure Application Gateways
- Microsoft Azure KeyVault
- Microsoft Azure Load Balancers
- Microsoft Azure NetApp Files
- Microsoft Azure Kubernetes Service (AKS)

- PowerShare uses architecture deployed on the Microsoft Azure cloud as depicted below.



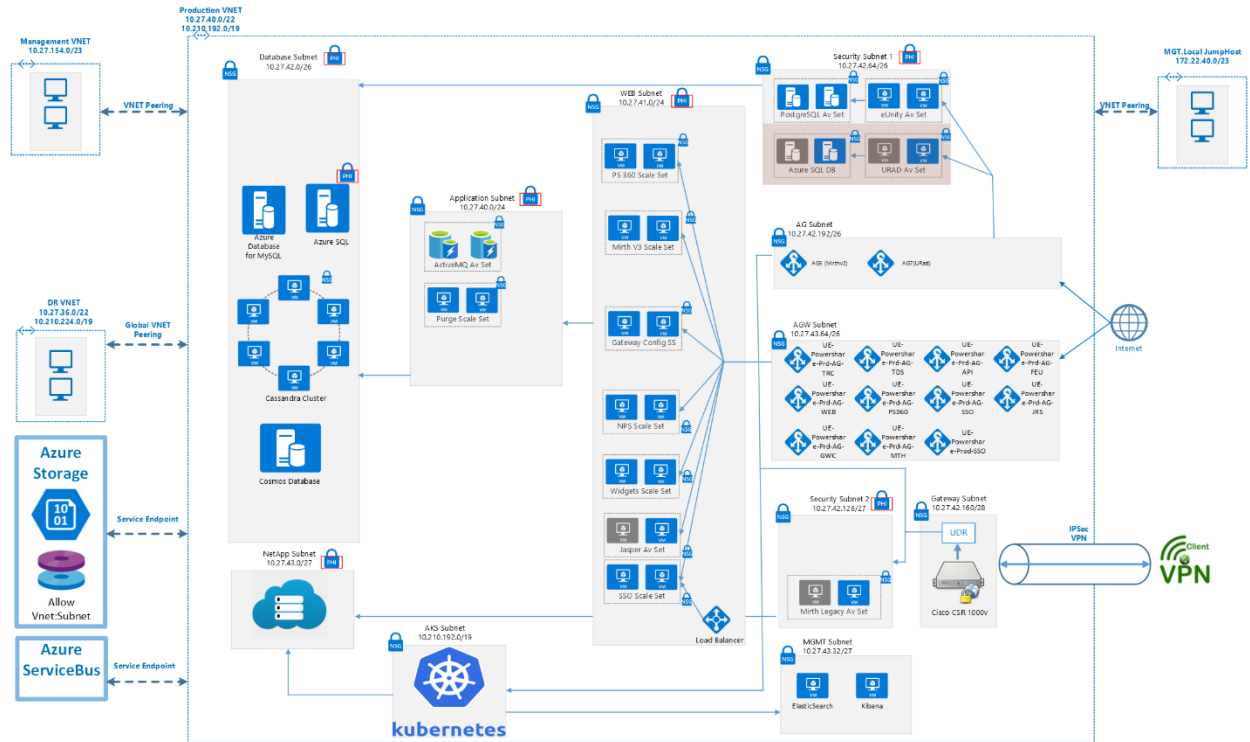


Figure 10: Microsoft Azure Disaster Recovery

PowerShare implements all its web interfaces as stateless using the Representational State Transfer (REST) application programming interface (API) and supporting Security Assertion Markup Language (SAML) 2.0 tokens for security. It leverages a rich combination of software products, including:

- OSs and web software: VMware ESXi, CentOS Linux, Red Hat Linux, Linux, Apache Tomcat, Apache ActiveMQ, Microsoft Windows Server 2016
- Databases: MySQL, Apache Cassandra, Microsoft Azure SQL Database, Microsoft Azure Cosmos DB
- Configuration management/monitoring: Microsoft Azure Monitor
- Image viewing and processing: eUnity, Mirth

Studies and metadata enter the PowerShare system via a variety of interfaces, including a web application uploader, widgets, uploader API, or accelerator gateway, that sends a manifest file with references for items in a study (e.g., images). The input data is processed by a series of applications that process and store images and Health Level 7 (HL7) metadata with pointers linking the information. The processed information can then be retrieved for viewing or distribution

mPower Infrastructure and Software

mPower is built using container-based cloud architecture. Hosted by Microsoft Azure, the application infrastructure and platform services include platform-as-a-service (PaaS) products such as Microsoft Azure container services' managed Kubernetes orchestration system (AKS) and a fully managed Microsoft Azure Database for PostgreSQL database.

For infrastructure-as-a-service (IaaS), mPower uses Microsoft Azure Log Analytics, Microsoft Azure Application Insights, Microsoft Azure Load Balancer, regional and geographic redundant storage accounts, and Domain Name System (DNS).

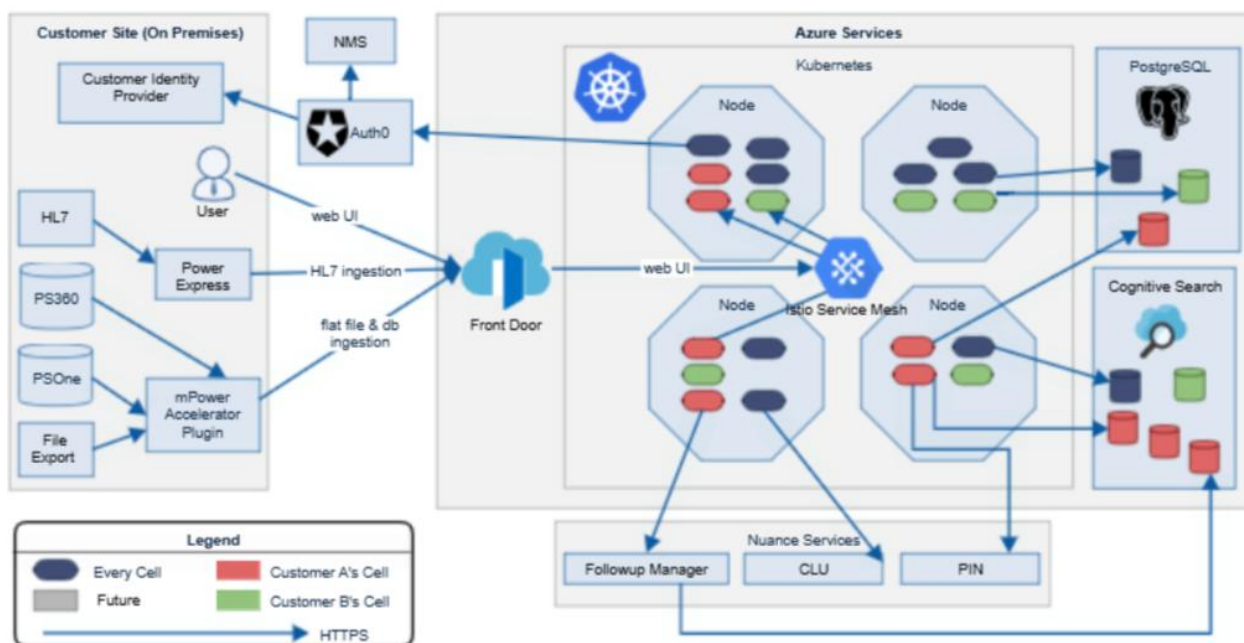


Figure 11: mPower Architecture

Precision Imaging Network Infrastructure and Software

PIN is hosted primarily in the Microsoft Azure East US region. The failover (disaster recovery [DR]) regions are West US and West 2 US. Within a region, the infrastructure is split into two parts: Core and Host. Core provides all of the PIN functionality with the exception of the hosting of third-party services. As a security precaution, third-party services are explicitly hosted in a separate cluster in a network environment that is treated as external to Nuance (no network connectivity except for going through the public Internet).

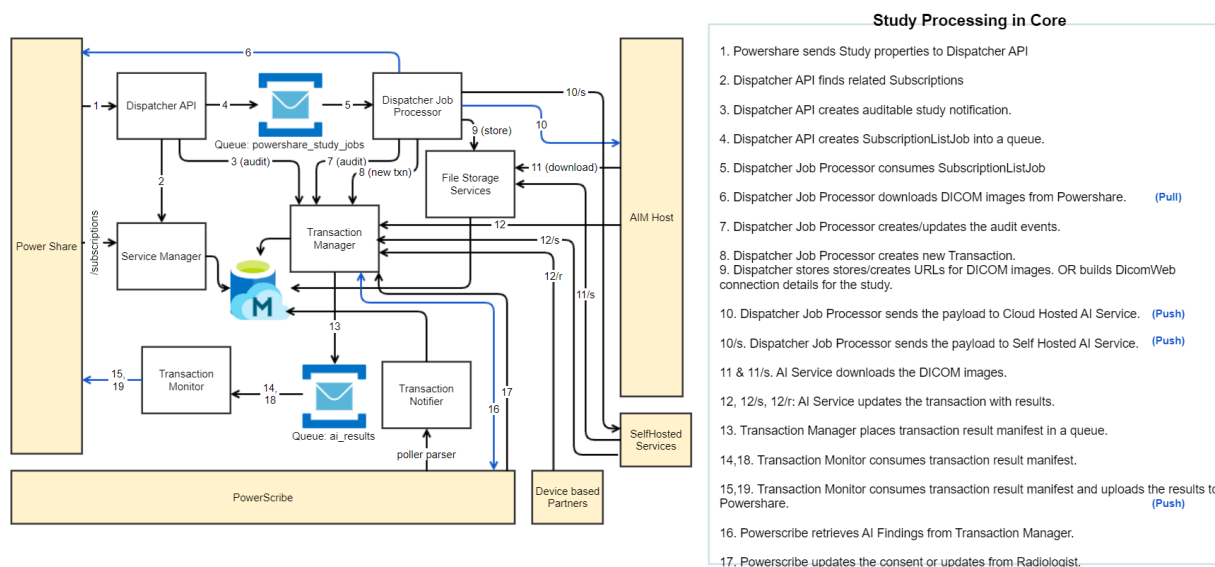


Figure 12: PIN Core Workflow

The figure below illustrates the Cloud Hosting Architecture.

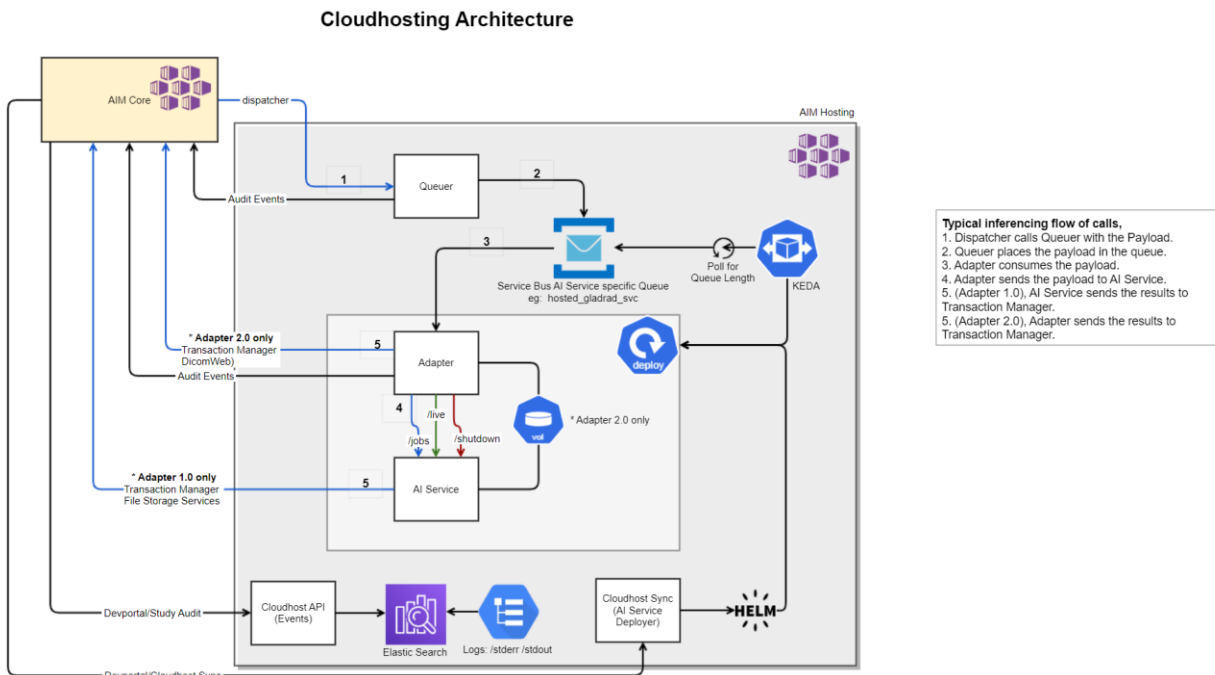


Figure 13: Cloud Hosting Architecture

All data is encrypted in-transit with HTTPS/TLS 1.2. All data is encrypted at rest via Microsoft Azure provided data encryption.

Both Core and Host production environments are able to fail over to their specified DR regions. The figure below illustrates the DR regions:

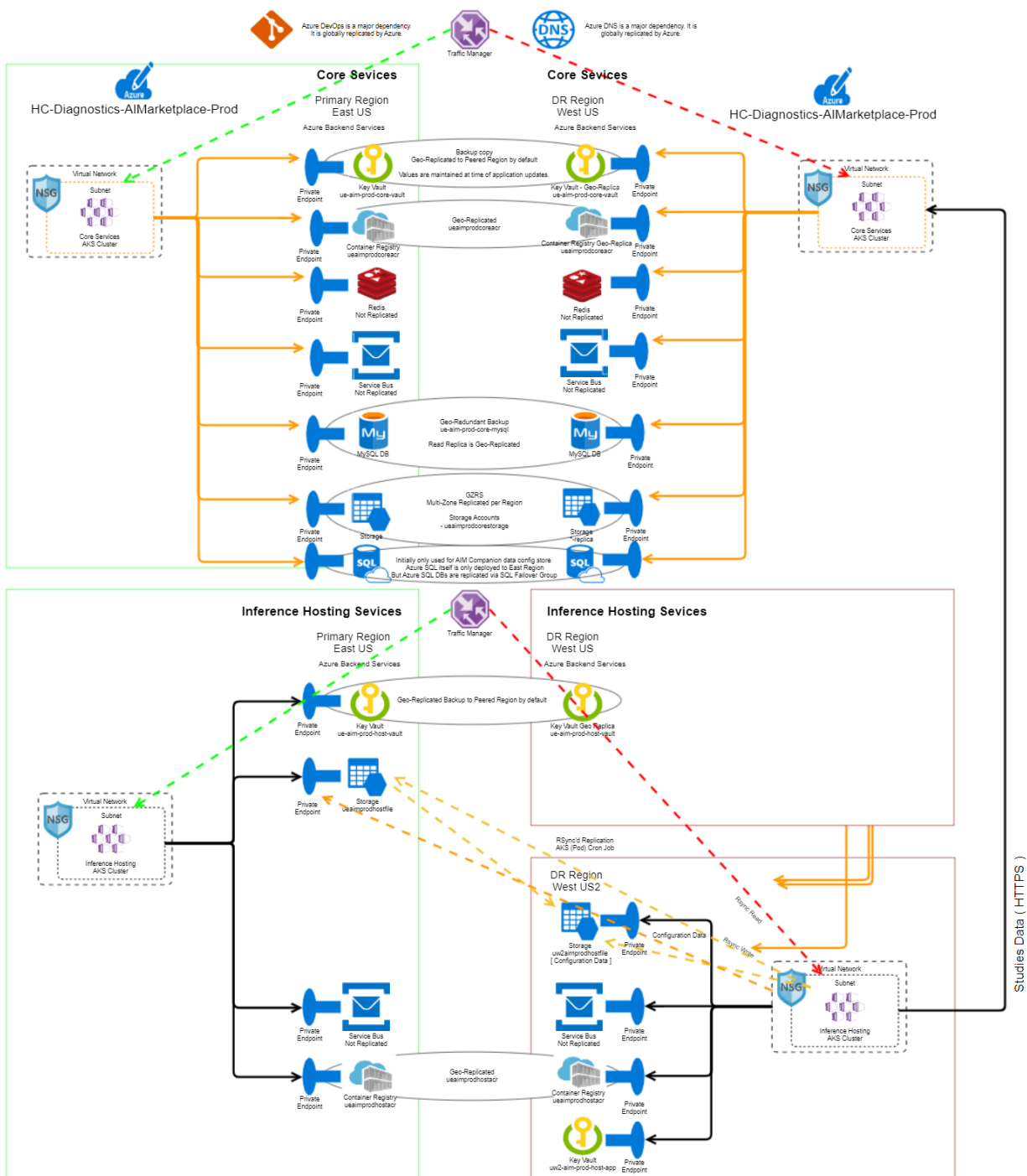
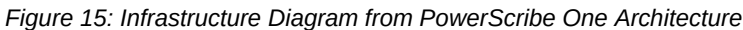


Figure 14: PIN Microsoft Azure Deployment

PowerScribe One is hosted in the Microsoft Azure public cloud. The primary region is Microsoft Azure East 2 US, and the secondary region is Central US. Microsoft Azure Traffic Manager is used to automatically or manually fail over from one region to the other if DR is required. In each region, the PowerScribe One Radiology Application Server, Admin Portal, AutoText Manager, and Mobile Bridge run on a Microsoft Azure Virtual Machine Scale Set. The backing store are Microsoft Azure SQL databases that are automatically backed up per automatic, geo-redundant backups.



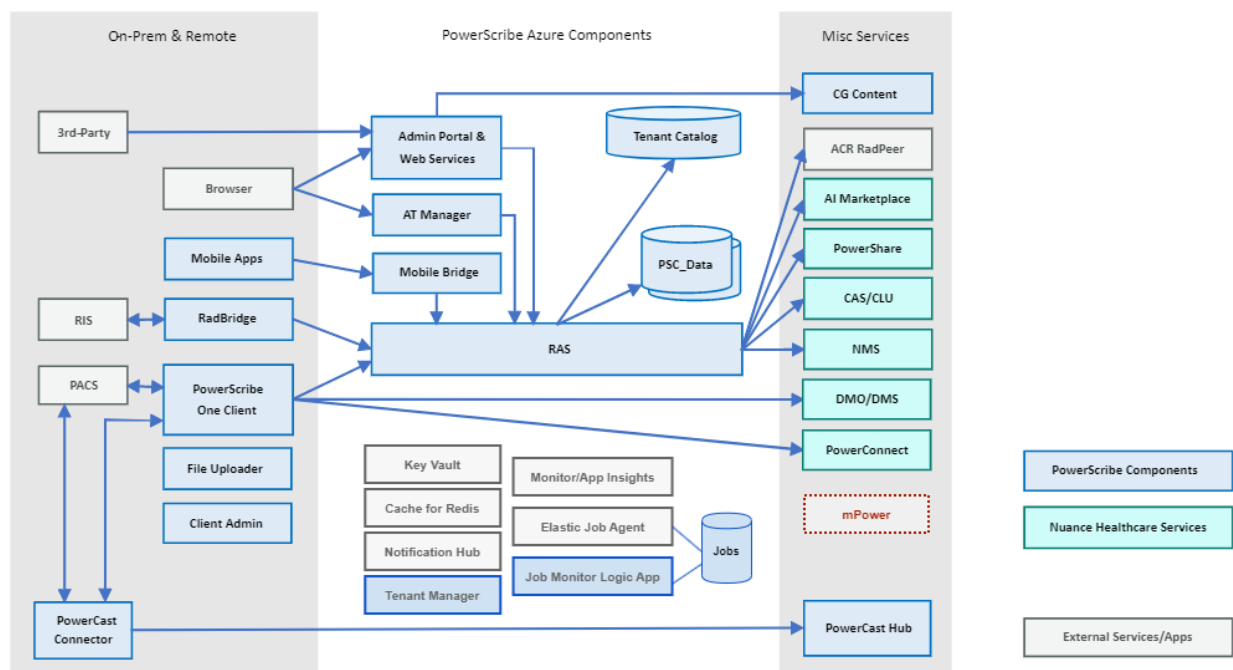


Figure 16: PowerScribe One Software Diagram

Dragon Professional Anywhere Infrastructure and Software

DPA is supported by active-active instances at three Microsoft Azure cloud computing data centers providing highly scalable, responsive, and available environments. Customer transactions are dispatched to one of two data centers by Microsoft Azure Traffic Manager, and traffic loads are balanced across components within each center. The virtualized environments are mirrored at each site and include:

- Web interfaces to the hosted services, virtualized clustered Windows Server 2012 R2 configurations running primarily C# and .NET code
- Dragon Medical Server (DMS) nodes, virtualized servers running proprietary C code that perform speech-to-text conversion
- Data services provided by clustered Microsoft Azure provisioned Microsoft SQL Server databases
- NMS servers, used for license validation, auto-text command processing, and other services. (Transactions are license-based and not user-based, although users are customer defined and assigned licenses.)
- Administrative servers supporting: Microsoft Entra ID monitoring, time services (network time protocol [NTP]), configuration management (Salt), email, deployment (Jump), and general management (e.g., SQL Studio)
- Network security protection leveraging Trend Micro Intrusion Prevention System (IPS) and Trend Micro Intrusion Detection System (IDS)
- Environments for Production, Development, Staging, and Quality Assurance (QA)

The figure below shows the process of how captured audio is submitted from the customer application interface via authorized, encrypted connections, converted to text, and returned to the customer application.

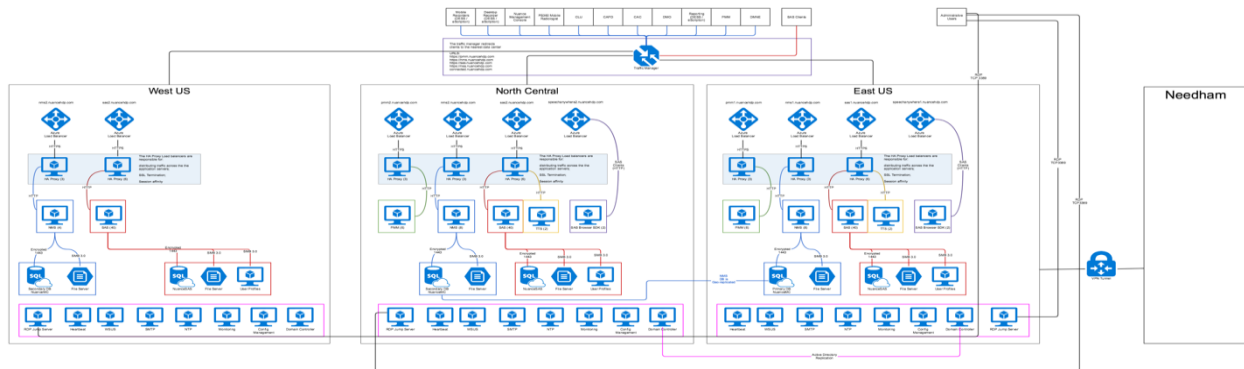


Figure 17: Customer Captured Audio

DAX and DAX Copilot Infrastructure and Software

DAX and DAX Copilot is deployed on Microsoft Azure cloud computing infrastructure, providing a highly scalable, responsive environment. The DAX and DAX Copilot environments include:

- Multiple iOS applications installed on the healthcare provider's iOS device
- A browser-based interface utilized by the Nuance documentation specialists
- A cloud-based backend hosted by Microsoft Azure

Backend processing including Natural Language Understanding (NLU) and Automated Speech Recognition (ASR) services

The following figure illustrates the DAX and DAX CoPilot architecture.

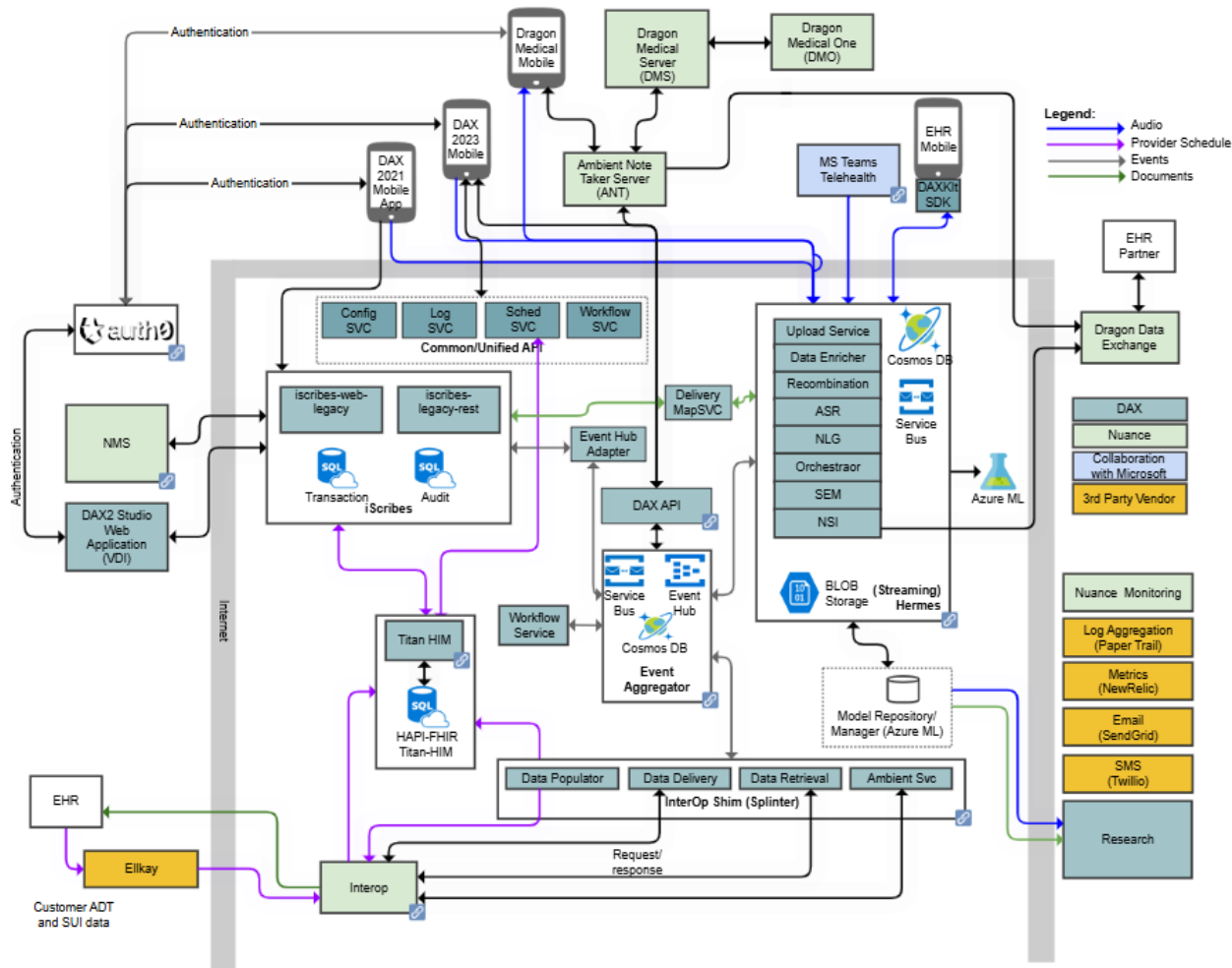


Figure 18: DAX and DAX CoPilot Diagram

iOS Application and Clinic Workflow

Healthcare providers use the Nuance iOS application to record audio of patient encounters. The DAX iOS application enables providers to start, stop, and pause recordings. After recording, the iOS application compresses, encrypts, and securely transmits the file to the cloud-based Nuance system. Once on the Nuance system, only the original provider and assigned documentation specialists have access.

Device Management and Practice Support

The Nuance DAX application currently works with a variety of iOS device configurations (e.g., corporate iPhone, personal iPhones, iPods), which Nuance supports with application updates. Device updates require only minimal experience with Apple devices and are covered as part of new customer onboarding and training.

Hosted Environment

The Nuance DAX software is developed and maintained by Nuance's in-house research and development (R&D) team. The Nuance R&D team is responsible for the development and maintenance of both the software in the hosted environment and the iOS application. The environment is hosted by IaaS provider Microsoft Azure.

End User Security Features

All Nuance end users have unique accounts and only have access to their own data. The DAX mobile application logs end users out after a period of inactivity and forces the users to re-authenticate. Unique user-selected personal identification numbers at each access point ensure that unauthorized personnel do not retrieve recordings, further protecting the in-application recording history and data. Accounts are locked after five incorrect login attempts, which prevents unauthorized users from accessing data.

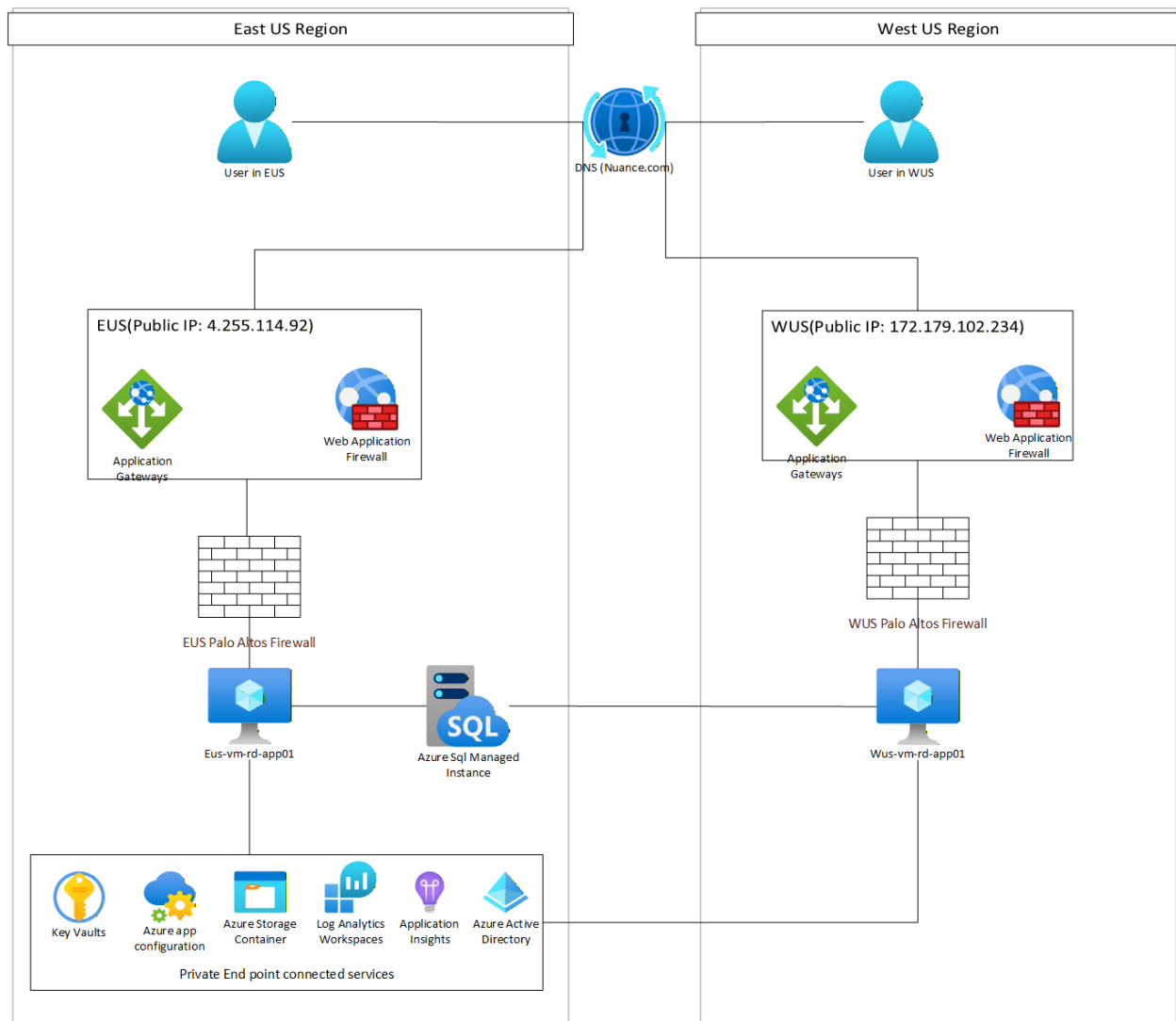


Figure 19: RDCM Architecture

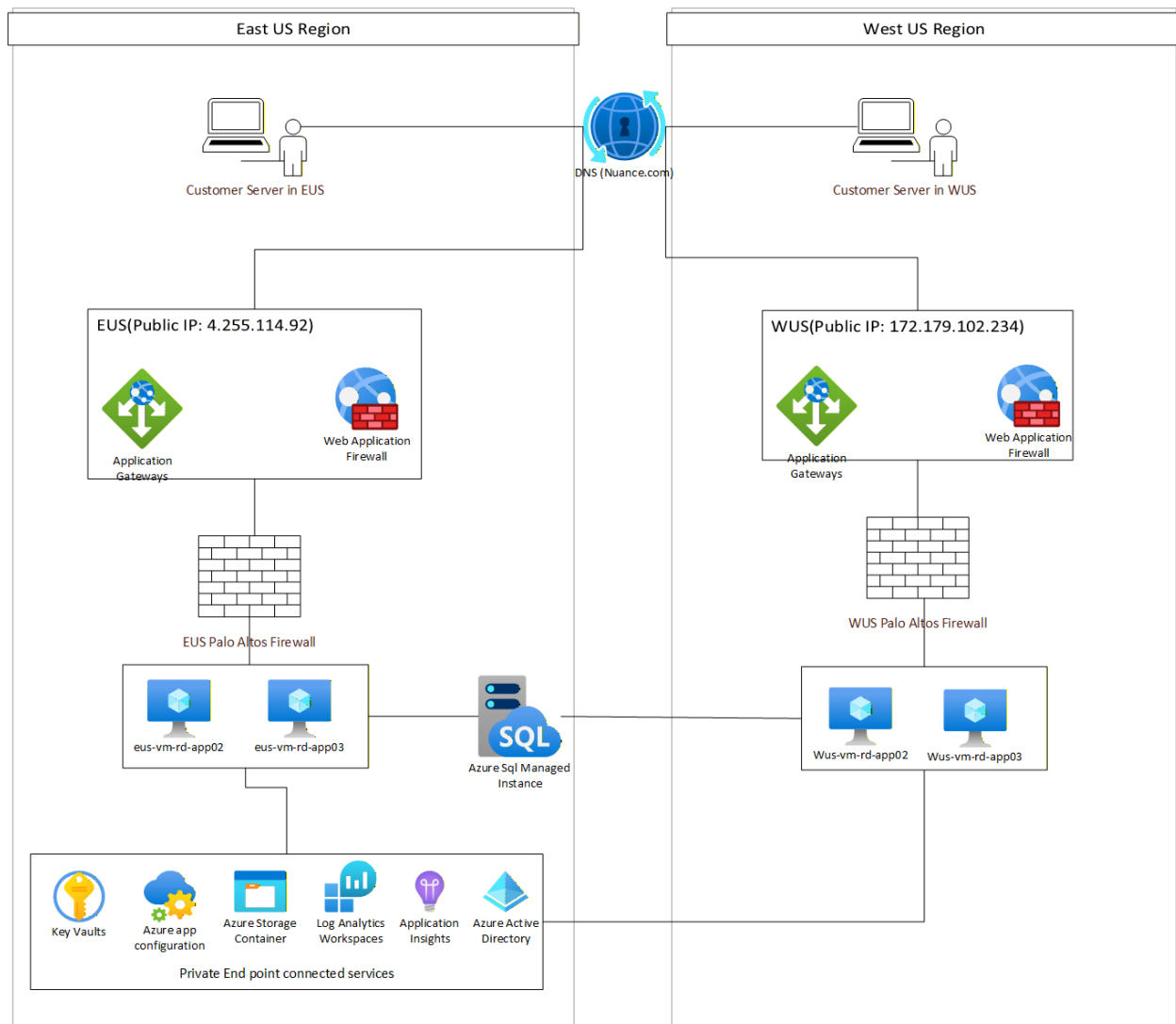


Figure 20: RDEX Architecture

People

The Company develops, manages, and secures Nuance Healthcare Systems via separate departments. The responsibilities of these departments are defined in the following table:

People	
Group/Role Name	Function
Executive Management	Responsible for overseeing company-wide activities, establishing and accomplishing goals, and managing objectives.
Engineering	Responsible for the development, testing, deployment, and maintenance of new code for Nuance Healthcare Systems.
Information Security (InfoSec)	Responsible for managing access controls and the security of the production environment.

People	
Group/Role Name	Function
Product Management	Responsible for overseeing the product life cycle, including adding new product functionality.
Human Resources (HR)	Responsible for onboarding new personnel, defining the roles and positions of new hires, performing background checks, and facilitating the employee termination process.
Technical Support Team	Responsible for working directly with customers to resolve application issues.
Site Reliability Engineering (SRE)	Responsible for monitoring of the systems.

Nuance is organized into functional areas as depicted in the following diagram and described below. Nuance Healthcare is a business segment of the larger Nuance Communications, Inc. Segments of the Nuance Healthcare organization relevant to the current assessment are shown below. The following organization chart reflects the Company's internal structure related to the groups discussed above:

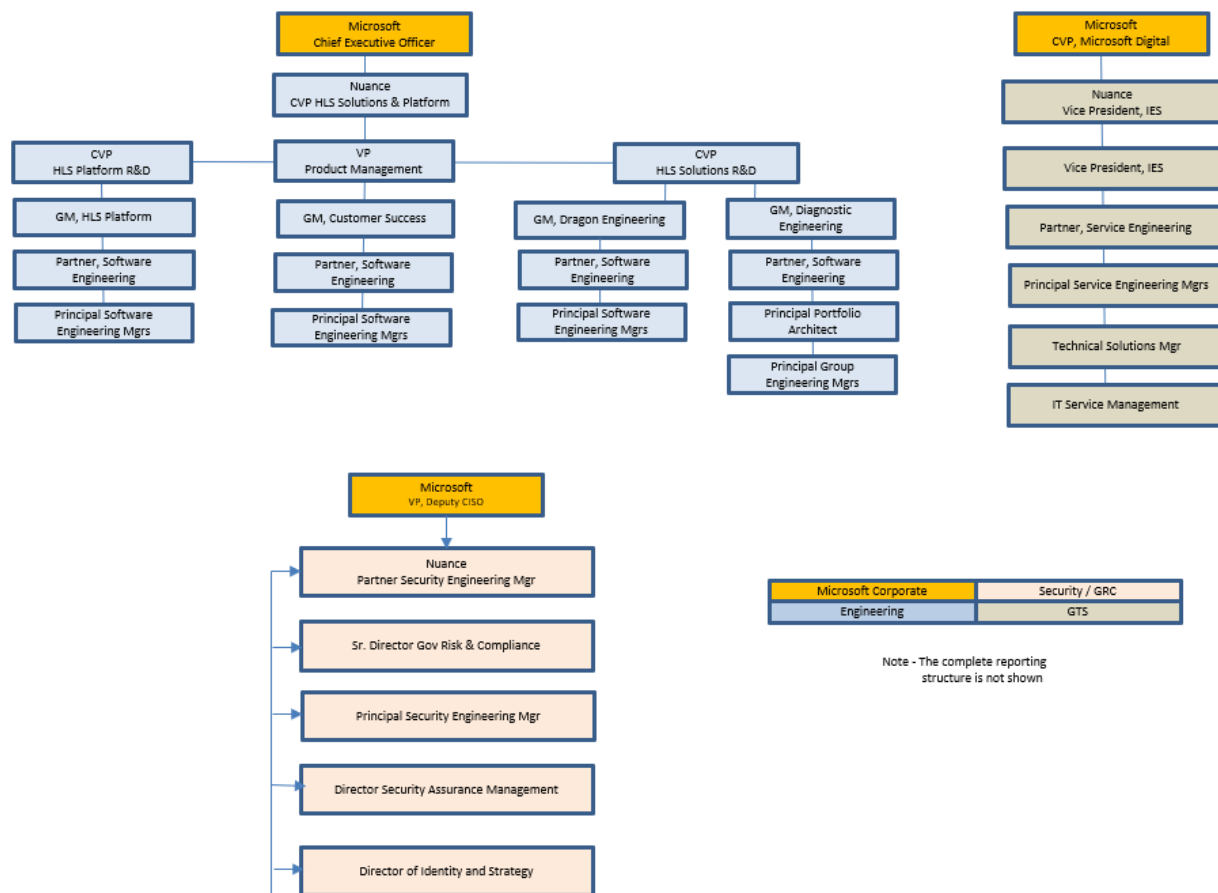


Figure 21: The Nuance Healthcare Systems Organization Chart

Procedures

Procedures include the automated and manual procedures involved in the operation of the Nuance Healthcare Systems. Procedures are developed and documented by the respective teams for a variety of processes, including those relating to product management, engineering, technical operations, security, information technology (IT), and HR. These procedures are drafted in alignment with the overall information security policies and are updated and approved as necessary for changes in the business, but no less than annually.

The following table details the procedures as they relate to the operation of the Nuance Healthcare Systems:

Procedures	
Procedure	Description
Logical Access	How the Company restricts logical access, provides and removes that access, and prevents unauthorized access.
System Operations	How the Company manages the operation of the system and detects and mitigates processing deviations, including logical security deviations.
Change Management	How the Company identifies the need for changes, makes the changes using a controlled change management process, and prevents unauthorized changes from being made.
Risk Mitigation	How the Company identifies, selects, and develops risk mitigation activities arising from potential business disruptions and the use of vendors and business partners.

Processes have been defined and implemented to cover the following key security life cycle areas:

- Personnel hiring, training, and compliance processes
- Performance of annual security risk assessments, ongoing security risk monitoring, and the implementation of associated mitigations
- Authentication or authorization to, changes to, and termination of information system access
- Change management
- Vulnerability and patch management
- Critical incident management
- Asset management
- Security and system operation monitoring

These processes are described in more detail in the control environment section of this document.

Data

Data refers to transaction streams, files, data stores, tables, and output used or processed by the Company. Through the API, the customer or end-user defines and controls the data they load into and store in the Nuance Healthcare Systems production network. Once stored in the environment, the data is accessed remotely from customer systems via the Internet.

Customer data is managed, processed, and stored in accordance with relevant data protection and other regulations and with specific requirements formally established in client contracts.

The Company has deployed secure methods and protocols for the transmission of confidential or sensitive information over public networks. Encryption is enabled for databases housing sensitive customer data.

The following table details the types of data contained in the production application for the Nuance Healthcare Systems:

Data		
Data Type	Description	Data Store
Customer information	Refers to user account, licensing, and configuration information.	NMS SQL Server Database, MySQL, Microsoft SQL Server
Speech profiles	Refers to personalized settings that enhance the accuracy and efficiency of speech recognition systems. These personalized settings include language and acoustical statistics of how an individual user pronounces sounds and uses words in a given language. These profiles are tailored to individual users, taking into account their unique voice characteristics, accents, and speaking styles.	Microsoft Azure File Storage
Persisted audio and text files, including protected health information (PHI)	Refers to audio recordings and text transcripts that are persistently stored and could contain PHI, such as patient identifiers, medical histories, or treatment details. These files are retained specifically for the purpose of training and refining speech recognition profiles, ensuring improved accuracy and personalization while adhering to strict confidentiality and security standards.	Microsoft Azure File Storage
Server images	Refers to virtual machine snapshots or disk images that capture the full state of a server, including its OS, configurations, and stored data.	Microsoft Azure Backup
Server configuration information	Refers to the stored details that define how a server is set up and operates, including system settings, network configurations, installed software, and security policies.	Microsoft Azure DevOps managed repositories, Red Hat Ansible Automation Platform on Microsoft Azure
Code base	Refers to the complete set of software assets used in a system, including vendor-provided software and firmware, associated licenses, and internally developed application product code.	Microsoft Azure DevOps managed repositories

The following data categories are associated with each of the products in the scope of the assessment. Nuance applications are source systems that may, or may not, feed into customers' EHRs. Thus, Nuance is subject to HIPAA as a Business Associate of its customers. While audio and associated text data is retained, it is only used to refine the speech-to-text or other analytic models. Data flows for each of the products are described in the product architecture and infrastructure overview sections.

CDI and CAPD Data

- Customer information, including user account, licensing, and configuration information (NMS Microsoft SQL Server database)

- Text input, processed documents, derived information
- Aggregated case information for CDI and CAPD and transient information stored in relational and non-relations databases
- VM images
- Server configuration information
- Code base, including vendor software and firmware, associated licenses, and developed application product code

PowerShare Data

- Customer information, including user account, licensing, and configuration information
- Radiology DICOM files (Microsoft Azure NetApp File storage)
- Associated radiology reports - HL7 data (MySQL, Microsoft SQL Server)
- Server images (Microsoft Azure Marketplace)
- Server configuration information (Salt)
- Code base, including vendor software and firmware, associated licenses, and developed application product code (Microsoft Azure DevOps)

mPower Data

- Customer information - user account, licensing, configuration information, audit logs.
- Server configuration information
- Reporting database
- Conceptual tagging (grouping of meta data)

The Nuance data retention policy is designed to maintain only the minimum necessary PHI and personally identifiable information (PII) to provide necessary services. To that end, only seven years' worth of data is to be retained in Nuance's production environment. Nuance purges and destroys data annually greater than seven years old.

mPower is a retrospective analysis tool and contains PHI. A physician or user logs into the mPower using an approved method. Once logged in, the data that can be accessed by the user is displayed using several backend databases. See diagram below.

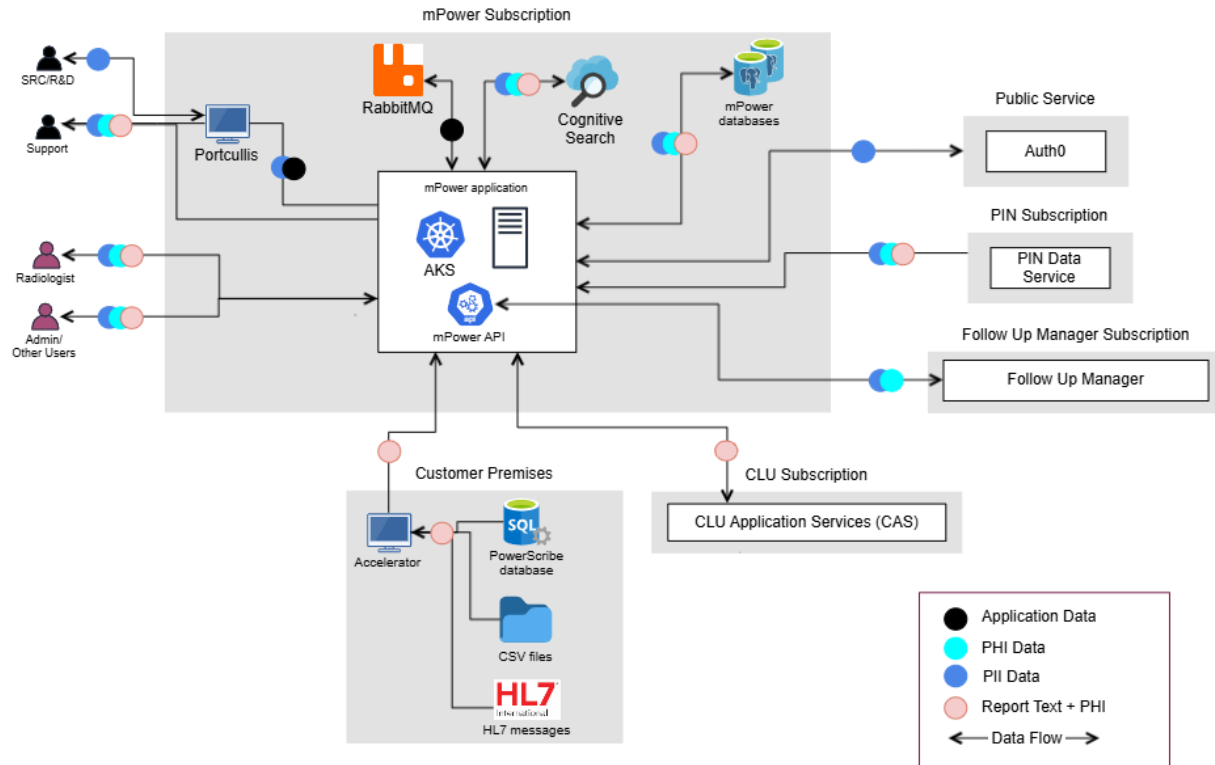


Figure 22: mPower Architecture

Precision Imaging Network Data

PIN processes diagnostic imaging studies as its input. Healthcare facilities route the studies via DICOM to PowerShare and PowerShare makes the studies available to PIN. PIN runs rules to determine what processing needs to be done and executes the appropriate AI. Acting as a repository of intelligence for multiple applications, PIN keeps the data and makes it available when appropriate. If configured, it can add DICOM-compatible results to the study by pushing it to the PACS (or other DICOM destination).

PowerScribe One Data

The following data categories are associated with the PowerScribe One product.

PowerScribe One leverages Nuance's CLU technology for all reports and orders. This underlying technology extracts data to drive workflows that automate the utilization of clinical guidance, categorization of procedure codes, and delivery of follow-up recommendations.

This technology is hosted in the Nuance Microsoft Azure environment. At the execution of a relevant PowerScribe One capability, the report text, exam description (e.g., chest CT), and other report metadata is passed to Microsoft Azure where the Nuance CLU engine will parse the text. The results are then passed back to the locally hosted server and presented to the radiologist.

The Nuance CLU technology is only offered as a hosted service by Microsoft Azure. The Nuance CLU technology cannot be deployed onsite within the customer's data center. The connection to the Microsoft Azure data center encrypts the data passed back and forth from the PowerScribe system, via TLS 1.2. The customer does not need a Secure Sockets Layer (SSL) certificate; however, they do need to open their firewall to allow PowerScribe to connect to the Microsoft Azure data center over an SSL connection.

In order to set up and configure CLU, the Nuance Professional Services team will have a CLU account created for the customer, and then configure the connection within the PowerScribe Admin Portal.

Clinical Content

PowerScribe One utilizes external clinical content as part of its processes. This content is developed and updated over time separate from the locally deployed PowerScribe One server.

Dragon Professional Anywhere Data

The following data categories are associated with the DPA product. While audio and associated text data is retained, it is only used to refine the speech-to-text or other analytic models. Data flows are described in the product Infrastructure and Software section.

- Customer information, including user account, licensing, and configuration information (NMS Microsoft SQL Server database)
- Speech profiles (Microsoft Azure Files system)
- Persisted audio and text files, including PHI
- Server images
- Server configuration information
- Code base, including vendor software and firmware, associated licenses, and developed application product code

DAX / DAX Copilot Data

The following data categories are associated with the DAX product. Audio and associated text data is retained for the purposes of refining the speech-to-text or other analytic models.

- Customer information, including user account, licensing, and configuration information
- Speech profiles for ASR and NLU
- Persisted audio and text files, including PHI
- Server images
- Server configuration information

Code base, including vendor software and firmware, associated licenses, and developed application product code

System Incidents

There were no identified significant system incidents that (a) were the result of controls that were not suitably designed or operating effectively to achieve one or more of the service commitments and system requirements or (b) otherwise resulted in a significant failure in the achievement of one or more of those service commitments and system requirements from May 1, 2025 to April 30, 2026.

The Applicable Trust Services Criteria and Related Controls

Applicable Trust Services Criteria

The Trust Services Categories that are in scope for the purposes of this report are as follows:

- Security: Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the confidentiality of information or systems and affect the entity's ability to meet its objectives.
- Confidentiality: Information designated as confidential is protected to meet the entity's objectives.

Many of the criteria used to evaluate a system are shared amongst both in-scope categories; for example, the criteria related to risk assessment apply to both the security and confidentiality categories. As a result, the criteria for the security and confidentiality categories are organized into (a) the criteria that are applicable to both categories (common criteria) and (b) criteria applicable only to a single category. The common criteria constitute the complete set of criteria for the security category. For the category of confidentiality, a complete set of criteria is comprised of all the common criteria and all the criteria applicable to confidentiality.

The common criteria are organized as follows:

1. Control environment: The criteria relevant to how the entity is structured and the processes the entity has implemented to manage and support people within its operating units. This includes criteria addressing accountability, integrity, ethical values, qualifications of personnel, and the environment in which they function.
2. Information and communication: The criteria relevant to how the entity communicates its policies, processes, procedures, commitments, and requirements to authorized users and other parties of the system and the obligations of those parties and users to the effective operation of the system.
3. Risk assessment: The criteria relevant to how the entity (i) identifies potential risks that would affect the entity's ability to achieve its objectives, (ii) analyzes those risks, (iii) develops responses to those risks including the design and implementation of controls and other risk mitigating actions, and (iv) conducts ongoing monitoring of risks and the risk management process.
4. Monitoring activities: The criteria relevant to how the entity monitors the system, including the suitability and design and operating effectiveness of the controls, and acts to address deficiencies identified.
5. Control activities: The criteria relevant to the actions established through policies and procedures that help ensure that management's directives to mitigate risks to the achievement of objectives are carried out.
6. Logical and physical access controls: The criteria relevant to how the entity restricts logical and physical access, provides and removes that access, and prevents unauthorized access.
7. System operations: The criteria relevant to how the entity manages the operation of system(s) and detects and mitigates processing deviations, including logical and physical security deviations.
8. Change management: The criteria relevant to how the entity identifies the need for changes, makes the changes using a controlled change management process, and prevents unauthorized changes from being made.

9. *Risk mitigation:* The criteria relevant to how the entity identifies, selects, and develops risk mitigation activities arising from potential business disruptions and the use of vendors and business partners.

This report is focused solely on the security and confidentiality categories. The Company has elected to exclude the availability, processing integrity, and privacy categories.

Control Environment

Organizational Structure

Nuance's organizational structure provides a framework within which its objectives are planned, executed, controlled, and monitored. Significant aspects of establishing an effective organizational structure include defining key areas of authority and responsibility and establishing appropriate lines of reporting. Nuance executive management has ultimate responsibility for defining these areas of authority and responsibility and for establishing reporting relationships and authorization protocols. The executive and organizational structure, lines of authority, reporting, and responsibility were summarized above.

Nuance and Microsoft Executive Leadership ensure the organization follows appropriate governance standards.

Human Resources

Microsoft hiring managers define job requirements prior to recruiting, interviewing, and hiring. Job requirements include the primary responsibilities for and tasks involved in the job, the background skills needed to perform the job, and the personal qualifications desired.

Microsoft employees create individual core priorities that align with those of their manager, organization, and Microsoft, and are supported with customer-centric actions and measures. These core priorities are established when an employee is hired, and then updated during one-on-one connect meetings with their manager. The primary focus of the connect meetings is to assess employee performance against their priorities and to agree on an updated list of priorities going forward.

Information and Communication

Nuance maintains internal SharePoint and Confluence sites that contain detailed application, architecture, and system information and processes, providing employees with access to information on application system functions, implementation, and operation.

Ticketing systems provide a record and notification basis of changes, Customer Service Center recorded issues, and incidents.

Internal email is also used to communicate time-sensitive information regarding security and system availability, notifying key personnel in the event of problems. External emails are used to inform customers of issues, changes, and updates to product functionality.

In order to help identify, capture, and communicate pertinent information in a form and timeframe that enables people to carry out their responsibilities, policies are in place that establish information policies with clear responsibility for the quality of information used to communicate operational, financial, and compliance-related information that makes it possible to run and control the business. These policies deal with not only internally generated data, but also information about external events, activities, and conditions, such as security incidents, necessary to inform business decision making and external reporting.

Company personnel receive a clear message from top management that control responsibilities must be taken seriously. Personnel understand their own role in the internal control system, as well as how individual activities relate to the work of others. Personnel have a means of communicating significant information upstream. There also is effective communication with external parties, such as customers, suppliers, regulators, and shareholders.

Internal Communication

Nuance has implemented various methods of communication to help ensure that employees understand their individual roles and responsibilities and ensure that significant events are communicated. These methods include training new employees on Company policy and commitments, security awareness training for employees, all-hands employee meetings, and the use of email and internal collaboration tools to communicate time-sensitive information.

External Communication

Nuance has implemented various methods of communication to help ensure that customers understand Nuance's role and responsibilities in processing customer transactions and ensure that significant events are communicated in a timely manner. These methods include the use of email and Nuance's customer contact line to communicate time-sensitive information.

Nuance utilizes its public-facing website to communicate relevant information regarding the design and operation of the Nuance Healthcare Systems, as well as Nuance's commitments to external customers. The website also features a portal where customers can communicate with Nuance for system support or to report any incidents or concerns related to the operation or security of the systems.

Risk Assessment and Mitigation

Information Security Risk Management (ISRM) is a formal and repeatable method for identifying information security risks, determining risk impact and likelihood, and implementing security controls that are appropriate and justified by the risk. Nuance ensures that information (including customer information) remains protected from a loss of:

- Confidentiality: Information will be accessible only to authorized individuals.
- Integrity: The accuracy and completeness of information will be maintained.

As part of the ISRM process, when a risk is identified (e.g., audit finding), it is logged and assessed with an understanding of:

- Nuance business processes
- The impact on Nuance assets, including:
 - The dependency of any business processes
 - The value of the asset to Nuance or to Nuance customers
 - The criticality of the asset to Nuance or to Nuance customers
- The technical systems in place supporting Nuance business
- The legislation, regulation, and/or compliance requirements to which Nuance is subject
- Existing security policy exceptions

Identified risks are assigned to an owner, logged, and managed using a risk-module tracking tool.

If the decision is to mitigate a risk, additional activities or controls are identified and implemented via a risk treatment plan which is documented by the asset owner and/or risk owner. Any identified “accepted” risks are evaluated at least annually, and informed decisions are made in relation to the risk treatment.

The InfoSec and Operational teams are responsible for identifying risks that threaten the achievement of security and confidentiality. Leadership and management have implemented a process for identifying, analyzing, and addressing relevant risks and aligning the risks with the annually developed organizational strategy and objectives.

Risk Identification

Nuance has considered significant interactions between itself and relevant external parties and the risks that could affect the Company’s ability to provide reliable service to its user entities. Key members of the Executive Management and operational teams meet annually to identify and review risks to the systems. These discussions culminate in the creation of a comprehensive annual risk assessment that includes formal mitigation strategies for risks beyond Nuance’s acceptable thresholds. Other inputs into these risk discussions are the potential impacts of developing technologies, the constantly changing landscape of regulatory and legislative requirements, and the annual reviews of the operating effectiveness of key controls. These risks are documented in a Company wiki.

Risk Factors

Management considers risks that can arise from both external and internal factors, including those described below.

- External factors
 - Technological developments
 - Changing customer needs or expectations
 - Competition that could alter marketing or service activities
 - New legislation and regulations that could force changes in policies and strategies
 - Natural catastrophes that could lead to changes in operations or information systems
 - Economic changes that could have an impact on management decisions
- Internal factors
 - Significant changes in policies, processes, or personnel
 - Types of fraud, fraud incentives, pressures, opportunities, attitudes, and rationalizations for employees
 - A disruption in information systems processing
 - The quality of personnel hired and methods of training utilized
 - Changes in management responsibilities

Risk Analysis

Risk analysis includes the identification of key business processes where potential exposures of some consequence exist, as well as significant changes to those processes. Once the significance and likelihood of risk have been assessed, management considers how the risk should be managed. This involves a judgment based on assumptions about the risk and a reasonable analysis of the costs associated with reducing the level of risk. Necessary actions are taken to reduce the significance or likelihood of the risk occurring and to identify the control activities necessary to mitigate the risk. Management identifies these

control activities and documents them. Management reviews the assessed risk levels annually and documents the risk assessment in the annual risk program.

Potential for Fraud

Management considers the potential for fraud when assessing the risks to Nuance's objectives. The potential for fraud can occur in both financial and non-financial reporting. Other types of fraud include the misappropriation of assets and illegal acts, such as violations of governmental regulations.

Management realizes that the potential for fraud can occur when employees are motivated by certain pressures or incentivized to commit fraud. The absence of controls, or ineffective controls, provides an opportunity for fraud when combined with an incentive to commit fraud. Therefore, documented policies and procedures are in place to guide personnel in identifying the potential for fraud as part of the risk assessment process. The risk assessment is performed annually and considers the potential for fraud.

Risk Mitigation

Policies and procedures are in place to guide personnel in risk mitigation activities. Nuance has developed monitoring processes, as well as policies, procedures, and communications, to meet the Company's objectives during response, mitigation, and recovery efforts. Security stakeholders perform a risk assessment annually that includes an evaluation of risk mitigation control activities for risks arising from potential business disruptions. Disaster recovery and business continuity plans are in place to guide personnel in procedures to protect against disruptions caused by an unexpected event. The plans are reviewed, updated, and approved annually based on a business impact analysis performed during the annual risk assessment process. The Company maintains insurance to offset the financial impact of a risk materializing.

A third-party management standard is in place and includes the following:

- Specific requirements for a vendor and business partner
- A due diligence process performed prior to accepting new vendors or business partners
- A monitoring process to review vendor and business partner compliance
- Termination of contract

The Supplier Risk Management Standard is reviewed and updated annually and on an ad-hoc basis as needed.

Vendors are evaluated in accordance with Microsoft's processes and are approved by management prior to receiving access to customer data. Nondisclosure agreements for confidentiality and data protection are required to be signed before information designated as confidential is shared with third parties.

Monitoring

Nuance Global Security has defined the Global Security Framework Policy to provide management direction and support for information security in accordance with business requirements, relevant laws, and regulations. The Global Security Organization develops and maintains this policy and publishes it to all internal employees and contractors.

Nuance has a dedicated InfoSec team responsible for managing information security and for providing annual control self-assessments, mitigating of threats, monitoring and addressing of vulnerabilities, and monitoring overall change for security impact. The InfoSec team has put in place an extensive set of policies and standards.

System Monitoring

The SRE teams use a variety of utilities including Prometheus, Grafana, Microsoft Azure Monitor, and native component monitoring capabilities to identify and detect possible operational anomalies and incidents. The information reported by these tools includes such items as loading and resource utilization, failover, ping response, and notifications of other exceptional system events. Alerts are reviewed by the Site Reliability Center staff and by security and SRE. Critical alerts result in the automatic creation of an incident ticket in the RemedyForce system and ServiceNow. Upon review, they may be entered into the Critical Incident Management system.

The Nuance Healthcare Systems' key performance indicators (KPIs) are available for viewing continuously through an online dashboard. These metrics, including resource utilization and capacity indicators are used to identify issues and plan for increased or changing capacity needs. Resulting change requests drive system updates to support increased capacity or to address other issues.

Microsoft Sentinel has been implemented for security information and event management (SIEM) to provide continuous data collection and log aggregation from all systems/applications. The aggregated data enables incident detection and provides sources for post-incident analysis and recovery. The SIEM dashboards are monitored by the Security Intelligence and Operations Center based in India and the United Kingdom and is accessible by the security leadership team in Burlington, MA.

Subservice Organization Monitoring

Data center space, power, communications connections, HVAC, and physical security services for the Nuance Healthcare Systems applications are provided by:

- Microsoft Azure East US (Ashburn, VA)
- Microsoft Azure North Central US (Chicago, IL)
- Microsoft Azure West US 2 (Quincy, WA)
- Microsoft Azure Canada East (Quebec)
- Microsoft Azure Canada Central (Toronto)

Control Activities

An entity's organizational structure provides a framework within which its objectives are planned, executed, controlled, and monitored. Significant aspects of establishing an effective organizational structure include defining key areas of authority and responsibility and establishing appropriate lines of reporting. Nuance executive management has ultimate responsibility for defining these areas of authority and responsibility and for establishing reporting relationships and authorization protocols. The executive and organizational structure, lines of authority, reporting, and responsibility were summarized above.

Nuance and Microsoft Executive Leadership ensures the organization follows appropriate governance standards.

Nuance control activities are defined through its established policies and procedures. Policy statements are documented and communicated through various communication methods within Nuance. Policies serve as the basis for procedures. Control activities are deployed through policies that establish what is expected and procedures that put policies into action. A list of policies and procedures is documented in the above Procedures section.

Logical Access

The Access Provisioning Process is a formal process for establishing and limiting staff access to Nuance Healthcare Systems. Employees are granted logical access to in-scope systems based on system documented requests that are reviewed and approved by appropriate management personnel.

In accord with the Access Termination Process, HR provides Nuance with notification of employee termination. Nuance disables the associated user ID and revokes the associated access privileges. The changes are documented in the request system.

Initial guidelines for role-based access control (RBAC) have been developed and are captured in the Nuance RBAC Guidelines document. RBAC is implemented as is feasible and appropriate but is dependent on the complex task of coordinating and defining consistent role definitions.

Administrative access to Microsoft Entra ID, UNIX/Linux servers, VMware servers, databases, storage, and network devices is restricted to authorized employees and is managed with the Nuance Access Provisioning Process. Account sharing is not allowed, with the exception of some generic “root” type accounts whose use is minimized. User identities are audited quarterly.

Policies and mechanisms require unique user identification numbers, names, and passwords for authentication of all Nuance staff. Password constraints are as follows:

- Passwords must have a minimum of eight characters, including two non-alphanumeric characters.
- Passwords expire every 90 days for non-privileged accounts and every 60 days for privileged accounts.
- Log-on sessions are terminated after five failed log-on attempts.
- The last 10 passwords cannot be reused.

System Operations

Nuance has a formalized Critical Incident Management process in place. Customers or internal staff/functions can identify potential issues which are vetted against incident criteria defined by the Critical Incident Management Process, and, if found to meet the criteria, result in the Critical Incident Manager opening an incident. The manager records the incident, reviews it with management and technical staff, and coordinates resolution actions which most likely result in the creation of change tickets. The Incident Manager is the responsible authority for coordinating communication, resolution actions, and eventual closure.

Change Management

For the Nuance Healthcare Systems, a set of customer administrators and their privileges is defined as part of the initial customer configuration by the Nuance Healthcare Provisioning Services group. That configuration is then implemented in production by Development Operations in accord with the Change Management Process.

Nuance has formalized change management procedures in place, as defined by the Change Management Process document. The process requires identification and recording of changes in the request tracking system, review and assessment of risk and potential impact of proposed changes, approval of proposed changes, testing of changes to verify operational functionality, and communication of change nature and status throughout the process. Proposed changes are evaluated to determine if they present a security or other operational risk and what mitigating actions, including employee and customer entity notifications, must be performed. All changes must have back out plans specified.

The SRE Change Advisory Board (CAB) management team meets weekly to review and schedule changes to the Nuance environments. Emergency changes follow the formal change management process, but at an accelerated timeline. Prior to initiating an emergency change, necessary approvals are obtained and documented. Changes to infrastructure and software are developed and tested in separate development or test environments before implementation. Developers are not permitted to implement changes independently or alter production environments.

Static and dynamic code scans are performed on every release, and vulnerability scans are performed quarterly against the application and its environment. Additionally, annual penetration testing is conducted on the production environment, while relevant application, system, and audit logs are actively monitored by Nuance Product Security.

Confidentiality

The following data categories are associated with the Nuance Healthcare Systems. While audio and associated text data is retained, it is only used to refine the speech-to-text or other analytic models. Data flows are described in the Infrastructure and Software section.

- Customer information, including user account, licensing, and configuration information (NMS Microsoft SQL Server database)
- Speech profiles, including personalized settings that enhance the accuracy and efficiency of speech recognition system (Microsoft Azure Files system)
- Persisted audio and text files, including PHI, that are audio recordings and text transcripts that are persistently stored
- Server images that are VM snapshots or disk images (Microsoft Azure Backup)
- Server configuration information including stored details that define how a server is set up and operates (Microsoft Azure DevOps managed repositories and the Ansible)
- Code base, including vendor software and firmware, associated licenses, and developed application product code– (Microsoft Azure DevOps managed repositories)

Complementary User Entity Controls (CUECs)

The Company's controls related to the Nuance Healthcare Systems cover only a portion of overall internal control for each user entity of the Nuance Healthcare Systems. It is not feasible for the service commitments, system requirements, and applicable criteria related to the system to be achieved solely by the Company. Therefore, each user entity's internal control should be evaluated in conjunction with the Company's controls and the related tests and results described in Section 4 of this report, taking into account the related CUECs identified for the specific criterion. In order for user entities to rely on the controls reported herein, each user entity must evaluate its own internal control to determine whether the identified CUECs have been implemented and are operating effectively.

The CUECs presented should not be regarded as a comprehensive list of all controls that should be employed by user entities. Management of user entities is responsible for the following:

Criteria	Complementary User Entity Controls
CC2.1	- User entities have policies and procedures to report any material changes to their overall control environment that may adversely affect services being performed by the Company according to contractually specified time frames. - Controls to provide reasonable assurance that the Company is notified of changes in: - User entity vendor security requirements - The authorized users list
CC2.3	- It is the responsibility of the user entity to have policies and procedures to: - Inform their employees and users that their information or data is being used and stored by the Company. - Determine how to file inquiries, complaints, and disputes to be passed on to the Company. - Determine which AI models process studies and when, related to PIN
CC6.1	User entities grant access to the Company's system to authorized and trained personnel.
CC6.4 CC6.5 CC7.2	User entities deploy physical security and environmental controls for all devices and access points, including the PowerShare Accelerator Gateway, residing at their operational facilities, including remote employees or at-home agents for which the user entity allows connectivity.

Subservice Organization and Complementary Subservice Organization Controls (CSOCs)

The Company uses Microsoft Azure as a subservice organization for data center colocation services. The Company's controls related to the Nuance Healthcare Systems cover only a portion of the overall internal control for each user entity of the Nuance Healthcare Systems. The description does not extend to the colocation services for IT infrastructure provided by the subservice organization. Section 4 of this report and the description of the system only cover the Trust Services Criteria and related controls of the Company and exclude the related controls of Microsoft Azure.

Although the subservice organization has been carved out for the purposes of this report, certain service commitments, system requirements, and applicable criteria are intended to be met by controls at the subservice organization. CSOCs are expected to be in place at the Microsoft Azure related to physical security and environmental protection, as well as backup, recovery, and redundancy controls related to availability. The Microsoft Azure's physical security controls should mitigate the risk of unauthorized access to the hosting facilities. The Microsoft Azure's environmental protection controls should mitigate the risk of fires, power loss, climate, and temperature variabilities.

Company management receives and reviews the Microsoft Azure SOC 2 Type 2 report annually. In addition, through its operational activities, Company management monitors the services performed by the Microsoft Azure to determine whether operations and controls expected to be implemented are functioning effectively. Management also communicates with the subservice organization to monitor compliance with the service agreement, stay informed of changes planned at the hosting facility, and relay any issues or concerns to Microsoft Azure management.

It is not feasible for the service commitments, system requirements, and applicable criteria related to the Nuance Healthcare Systems to be achieved solely by the Company. Therefore, each user entity's internal control must be evaluated in conjunction with the Company's controls and related tests and results described in Section 4 of this report, taking into account the related CSOCs expected to be implemented at Microsoft Azure as described below.

Criteria	Complementary Subservice Organization Controls
CC6.4	- The Microsoft Azure facilities are responsible for restricting data center access to authorized personnel. - The Microsoft Azure facilities are responsible for the 24/7 monitoring of data centers by closed circuit cameras and security personnel.
CC6.5 CC6.7	- Microsoft Azure is responsible for implementing controls for the transmission, movement, and removal of the underlying storage devices for their cloud-hosting services where Company systems reside. - Microsoft Azure is responsible for securely decommissioning and physically destroying physical production assets in its control.
CC6.5 C1.2	Microsoft Azure is responsible for purging or destroying electronic information containing confidential information when they are no longer used.
CC7.2	- The Microsoft Azure Facilities are responsible for the installation of fire suppression and detection and environmental monitoring systems at the data centers. - The Microsoft Azure Facilities are responsible for protecting data centers against a disruption in power supply to the processing environment by an uninterruptible power supply (UPS). - The Microsoft Azure Facilities are responsible for overseeing the regular maintenance of environmental protections at data centers.

Complementary Corporate-Level Controls

The Company also uses Microsoft Azure for HR functions and vendor management. The Company's controls related to the Nuance Healthcare Systems cover only a portion of the overall internal control for each user entity of the Nuance Healthcare Systems. The description does not extend to the HR functions or vendor management services provided by Microsoft Azure. Section 4 of this report and the description of the system only cover the Trust Services Criteria and related controls of the Company and exclude the related controls of Microsoft Azure.

Although the complementary corporate-level controls at Microsoft Azure have been carved out for the purposes of this report, certain service commitments, system requirements, and applicable criteria are intended to be met by the complementary corporate-level HR and vendor management controls at Microsoft Azure.

Company management receives and reviews the Microsoft Azure SOC 2 Type 2 reports annually. In addition, through its operational activities, Nuance management monitors the services performed by Microsoft Azure to determine whether operations and controls expected to be implemented are functioning effectively.

It is not feasible for the service commitments, system requirements, and applicable criteria related to the Nuance Healthcare Systems to be achieved solely by the Company. Therefore, each user entity's internal control must be evaluated in conjunction with the Company's controls and related tests and results described in Section 4 of this report, taking into account the related controls expected to be implemented at Microsoft Azure as described below.

Criteria	Complementary Corporate-Level Controls
CC1.1	• Microsoft Azure is responsible for providing the Microsoft Standards of Business Conduct and Security Policy to new employees and contractors and collecting acknowledgments. • Microsoft Azure is responsible for providing confidentiality agreements to new employees and contractors and collecting signed agreements. • Microsoft Azure is responsible for the completion of background checks for new employees and contractors.
CC1.2 CC1.3	• Microsoft Azure is responsible for the board of directors meeting annually, maintaining formal meeting minutes, and including directors that are independent of the Company. • Microsoft Azure is responsible for documenting the oversight responsibilities relative to internal control for the board of directors.
CC1.4 CC2.2	• Microsoft Azure is responsible for employees completing security awareness training upon hire and annually thereafter. • Microsoft Azure is responsible for managers completing performance appraisals for direct reports annually.
CC1.5	• Microsoft Azure is responsible for documenting disciplinary actions in a formalized sanctions policy.
CC4.1 CC4.2 CC9.2	• Microsoft Azure is responsible for establishing formal information agreements with and reviewing attestation reports for critical vendors.
CC6.2 CC6.3 CC6.5 CC6.6 CC6.7	• Microsoft Azure is responsible for managing logical access to the underlying network, virtualization management, security, and storage devices for its cloud-hosting services where the Nuance applications reside. • Microsoft Azure is responsible for creating and tracking access modification tickets based on quarterly access reviews. • Microsoft Azure is responsible for purging or destroying electronic media. • Microsoft Azure is responsible for the mobile device management (MDM) system.

Specific Criteria Not Relevant to the System

There were no specific security or confidentiality Trust Services Criteria as set forth in TSP Section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)* that were not relevant to the system as presented in this report.

Significant Changes to the System

There were no changes that are likely to affect report users' understanding of how the Nuance Healthcare Systems were used to provide the service from May 1, 2025 to April 30, 2026.

Report Use

The description does not omit or distort information relevant to the Nuance Healthcare Systems while acknowledging that the description is prepared to meet the common needs of a broad range of users and may not, therefore, include every aspect of the system that each individual user may consider important to their own particular needs.

Section 4

Trust Services Criteria, Related Controls and Tests of Controls Relevant to the Security and Confidentiality Categories

Control Environment Elements

The control environment represents the collective effect of various elements in establishing, enhancing or mitigating the effectiveness of specific controls. The control environment elements as described in the description of the system include, but are not limited to, the Code of Conduct, Policies and Procedures and Human Resources.

Our tests of the control environment included the following procedures, to the extent we considered necessary; (a) an inspection of Nuance's organizational structure including segregation of functional responsibilities and policies and procedures; (b) inquiries with management, operations, administrative and other personnel who are responsible for developing, ensuring adherence to and applying controls; (c) observations of personnel in the performance of their assigned duties; and (d) inspection of documents and records pertaining to controls.

Description of Tests Performed by Coalfire Controls, LLC

Our tests of operating effectiveness of controls included such tests as were considered necessary in the circumstances to evaluate whether those controls, and the extent of compliance with them, were sufficient to provide reasonable, but not absolute, assurance that the trust services security and confidentiality categories and criteria were achieved throughout the period May 1, 2025 to April 30, 2026. In selecting particular tests of the operating effectiveness of the controls, we considered (i) the nature of the controls being tested; (ii) the types of available evidential matter; (iii) the nature of the criteria to be achieved; (iv) the assessed level of control risk; and (v) the expected efficiency and effectiveness of the test. Such tests were used to evaluate fairness of the presentation of the description of the Nuance Healthcare Systems and to evaluate the operating effectiveness of specified controls.

Additionally, observation and inspection procedures were performed as it relates to system generated reports, queries, and listings within management's description of the system to assess the completeness and accuracy (reliability) of the information utilized in the performance of our testing of the control activities.

Trust Services Criteria, Related Controls and Tests of Controls Relevant to the Security and Confidentiality Categories

Control Environment			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC1.1	The entity demonstrates a commitment to integrity and ethical values.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.
CC1.3	Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.
	An organization chart is documented and defines the organizational structure and reporting lines.	Inspected the organization chart to determine that it was documented and defined the organizational structure and reporting lines.	No exceptions noted.

Control Environment			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Management has established defined roles and responsibilities to oversee the implementation of the security and control environment.	Inspected the information security policy to determine that management had established defined roles and responsibilities to oversee the implementation of the security and control environment.	No exceptions noted.
	Job descriptions are documented for employees supporting the service and include authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	Inspected job descriptions for a sample of employees supporting the service to determine that job descriptions were documented and included authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	No exceptions noted.
CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.
	Job descriptions are documented for employees supporting the service and include authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	Inspected job descriptions for a sample of employees supporting the service to determine that job descriptions were documented and included authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	No exceptions noted.

Control Environment			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC1.5	The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.
	Job descriptions are documented for employees supporting the service and include authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	Inspected job descriptions for a sample of employees supporting the service to determine that job descriptions were documented and included authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	No exceptions noted.

Information and Communication			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.		
	Control self-assessments are performed by management at least annually to gain assurance that controls are in place and operating effectively. Corrective actions are taken by management based on relevant findings and tracked to resolution.	Inspected the control self-assessment documentation to determine that control self-assessments were performed by management during the period to gain assurance that controls were in place and operating effectively and that corrective actions were taken by management based on relevant findings and tracked to resolution.	No exceptions noted.
	The Company has network and data flow diagrams that are available to authorized users upon request.	Inspected network and data flow diagrams to determine that they were documented and available to authorized users upon request.	No exceptions noted.
	A formal inventory of production system assets that includes asset owners is maintained, and changes to the inventory are logged.	Inspected the production system asset inventory to determine that a formal inventory of production system assets that included asset owners was maintained and changes to the inventory were logged.	No exceptions noted.
	Internal and external network vulnerability scans are performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	Inspected internal and external network vulnerability scans for a sample of quarters to determine that internal and external network vulnerability scans were performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	No exceptions noted.

Information and Communication			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during quarterly internal and external network vulnerability scans.	Inspected remediation plans for vulnerabilities identified during the sampled quarterly internal and external network vulnerability scans to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the scans.	No exceptions noted.
	A log management tool is utilized to identify trends that may have a potential impact on the Company's ability to achieve its security objectives and generates alerts when specific events occur.	Inspected the log management tool configurations to determine that a log management tool was utilized to identify trends that may have had a potential impact on the Company's ability to achieve its security objectives and generated alerts when specific events occurred.	No exceptions noted.
	The security owner subscribes to industry security bulletins and email alerts and uses them to monitor the impact of emerging technologies and security on the production systems.	Inspected example security bulletins and email alerts subscribed to by the security owner to determine that the security owner subscribed to industry security bulletins and email alerts and used them to monitor the impact of emerging technologies and security on the production systems.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.

Information and Communication			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Management has established defined roles and responsibilities to oversee the implementation of the security and control environment.	Inspected the information security policy to determine that management had established defined roles and responsibilities to oversee the implementation of the security and control environment.	No exceptions noted.
	Job descriptions are documented for employees supporting the service and include authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	Inspected job descriptions for a sample of employees supporting the service to determine that job descriptions were documented and included authorities and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of the system.	No exceptions noted.
	System changes are communicated to authorized internal users.	Inspected the ticket for a sample of system changes to determine that system changes were communicated to authorized internal users.	No exceptions noted.
	A formalized ethics and compliance policy is established and an anonymous communication channel is available for employees to report potential security issues or fraud concerns.	Inspected the formal ethics and compliance policy to determine that a formalized ethics and compliance policy was established and an anonymous communication channel was available for employees to report potential security issues or fraud concerns.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.		
	Customer Hosted Service Agreements, Hosted Service Orders, and the Privacy Statement include the communication of the Company's commitments to its customers.	Inspected the Hosted Service Agreement, Hosted Service Order templates, and the Privacy Statement to determine that the Company's commitments were communicated to customers.	No exceptions noted.

Information and Communication			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Customers are notified of critical changes that may affect their processing.	Inspected release notes and maintenance window notifications for a sample of critical changes to determine that the Company communicated critical changes to customers that could have affected their processing.	No exceptions noted.
	An external-facing support system is in place that allows users to report system information on failures, incidents, concerns, and other complaints to the appropriate personnel.	Inspected the customer reporting portal to determine that an external-facing support system was in place that allowed users to report system information on failures, incidents, concerns, and other complaints to the appropriate personnel.	No exceptions noted.
	Guidelines and technical support resources related to system operations are provided on the Company's website.	Inspected the Company's website to determine that guidelines and technical support resources related to system operations were provided on the Company's website.	No exceptions noted.

Risk Assessment			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.		
	The Company specifies its objectives in its annual risk assessment to enable the identification and assessment of risk related to the objectives.	Inspected documentation from the risk assessment performed during the period to determine that the Company specified its objectives in its annual risk assessment to enable the identification and assessment of risk related to the objectives.	No exceptions noted.
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.		
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
	A risk assessment is performed at least annually. As part of this process, threats and changes to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected risk assessment documentation to determine that a risk assessment was performed during the period and that, as part of this process, threats and changes to service commitments were identified and the risks were formally assessed.	No exceptions noted.

Risk Assessment			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
		Inspected risk assessment documentation to determine that the risk assessment included a consideration of the potential for fraud and how fraud may have impacted the achievement of objectives.	No exceptions noted.
CC3.3	The entity considers the potential for fraud in assessing risks to the achievement of objectives.		
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
	A risk assessment is performed at least annually. As part of this process, threats and changes to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected risk assessment documentation to determine that a risk assessment was performed during the period and that, as part of this process, threats and changes to service commitments were identified and the risks were formally assessed.	No exceptions noted.
		Inspected risk assessment documentation to determine that the risk assessment included a consideration of the potential for fraud and how fraud may have impacted the achievement of objectives.	No exceptions noted.
CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.		
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.

Risk Assessment			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A risk assessment is performed at least annually. As part of this process, threats and changes to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected risk assessment documentation to determine that a risk assessment was performed during the period and that, as part of this process, threats and changes to service commitments were identified and the risks were formally assessed.	No exceptions noted.
		Inspected risk assessment documentation to determine that the risk assessment included a consideration of the potential for fraud and how fraud may have impacted the achievement of objectives.	No exceptions noted.
	A configuration management tool (CMT) is in place to ensure that system configurations are deployed consistently throughout the environment.	Inspected CMT configurations to determine that a CMT was in place to ensure that system configurations were deployed consistently throughout the environment.	No exceptions noted.
	Penetration testing is performed at least annually to identify vulnerabilities that could be exploited to gain access to the production environment.	Inspected the penetration test report to determine that penetration testing was performed during the period to identify vulnerabilities that could have been exploited to gain access to the production environment.	No exceptions noted.
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during the annual penetration test.	Inspected remediation plans for vulnerabilities identified during the annual penetration test to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the annual penetration test.	No exceptions noted.

Monitoring Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.		
	Control self-assessments are performed by management at least annually to gain assurance that controls are in place and operating effectively. Corrective actions are taken by management based on relevant findings and tracked to resolution.	Inspected the control self-assessment documentation to determine that control self-assessments were performed by management during the period to gain assurance that controls were in place and operating effectively and that corrective actions were taken by management based on relevant findings and tracked to resolution.	No exceptions noted.
	Penetration testing is performed at least annually to identify vulnerabilities that could be exploited to gain access to the production environment.	Inspected the penetration test report to determine that penetration testing was performed during the period to identify vulnerabilities that could have been exploited to gain access to the production environment.	No exceptions noted.
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during the annual penetration test.	Inspected remediation plans for vulnerabilities identified during the annual penetration test to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the annual penetration test.	No exceptions noted.
	Internal and external network vulnerability scans are performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	Inspected internal and external network vulnerability scans for a sample of quarters to determine that internal and external network vulnerability scans were performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	No exceptions noted.

Monitoring Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during quarterly internal and external network vulnerability scans.	Inspected remediation plans for vulnerabilities identified during the sampled quarterly internal and external network vulnerability scans to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the scans.	No exceptions noted.
	Vendor risk assessments that include attestation report reviews are performed at least annually for all subservice organizations to evaluate the impact of noted exceptions on the service.	Inspected vendor risk assessment documentation for all subservice organizations to determine that vendor risk assessments that included attestation report reviews were performed during the period for all subservice organizations to evaluate the impact of noted exceptions on the service.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.		
	Control self-assessments are performed by management at least annually to gain assurance that controls are in place and operating effectively. Corrective actions are taken by management based on relevant findings and tracked to resolution.	Inspected the control self-assessment documentation to determine that control self-assessments were performed by management during the period to gain assurance that controls were in place and operating effectively and that corrective actions were taken by management based on relevant findings and tracked to resolution.	No exceptions noted.

Monitoring Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Vendor risk assessments that include attestation report reviews are performed at least annually for all subservice organizations to evaluate the impact of noted exceptions on the service.	Inspected vendor risk assessment documentation for all subservice organizations to determine that vendor risk assessments that included attestation report reviews were performed during the period for all subservice organizations to evaluate the impact of noted exceptions on the service.	No exceptions noted.

Control Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.		
	As part of its annual risk assessment, management selects and develops manual and IT general control activities that contribute to the mitigation of identified risks.	Inspected documentation from the risk assessment performed during the period to determine that, as part of its annual risk assessment, management selected and developed manual and IT general control activities that contributed to the mitigation of identified risks.	No exceptions noted.
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.		
	As part of its annual risk assessment, management selects and develops manual and IT general control activities that contribute to the mitigation of identified risks.	Inspected documentation from the risk assessment performed during the period to determine that, as part of its annual risk assessment, management selected and developed manual and IT general control activities that contributed to the mitigation of identified risks.	No exceptions noted.

Control Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.		
	Security incident response policies and procedures are documented and provide guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	Inspected the security incident response policies and procedures to determine that they were documented and provided guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
	Formal procedures are documented that outline the process the Company's staff follows to perform the following system access control functions: - Adding new users - Modifying an existing user's access - Removing an existing user's access - Restricting access based on separation of duties and least privilege	Inspected system access control procedures to determine that formal procedures were documented that outlined the process the Company's staff followed to perform the following system access control functions: - Adding new users - Modifying an existing user's access - Removing an existing user's access - Restricting access based on separation of duties and least privilege	No exceptions noted.
	Information security policies and procedures are documented and define the information security rules and requirements for the service environment.	Inspected the Company's information security policies and procedures to determine that they were documented and defined the information security rules and requirements for the service environment.	No exceptions noted.

Control Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
	A data classification policy is documented to help ensure that confidential data is properly secured and restricted to authorized personnel.	Inspected the data classification policy to determine that a data classification policy was documented to help ensure that confidential data was properly secured and restricted to authorized personnel.	No exceptions noted.
	Formal procedures that outline requirements for vulnerability management are documented and include the following components: - Methods for identifying vulnerabilities and frequency - Assessing the severity of identified vulnerabilities - Prioritizing and implementing remediation or mitigation activities for identified vulnerabilities based on severity and defined timelines - Handling of system components for which no measures are initiated to remediate or mitigate vulnerabilities	Inspected the vulnerability management procedures to determine that formal procedures that outlined requirements for vulnerability management were documented and included the following components: - Methods for identifying vulnerabilities and frequency - Assessing the severity of identified vulnerabilities - Prioritizing and implementing remediation or mitigation activities for identified vulnerabilities based on severity and defined timelines - Handling of system components for which no measures are initiated to remediate or mitigate vulnerabilities	No exceptions noted.

Control Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Formal policies and procedures that outline the requirements for vendor management are documented and include the following components: - Maintaining a list of subservice organizations - Requirements for the assessment of risks resulting from the procurement of third-party services - Requirements for the classification of third parties - Information security requirements for the processing, storage, or transmission of information by third parties - Requirements for dealing with vulnerabilities, security incidents, and malfunctions - Specifications for the contractual agreement and monitoring of third-party vendor requirements - Requirements for subservice organizations to maintain their own security practices and procedures - Annually reviewing attestation reports for subservice organizations or performing a vendor risk assessment	Inspected the vendor management policy to determine that formal policies and procedures that outlined the requirements for vendor management were documented and included the following components: - Maintaining a list of subservice organizations - Requirements for the assessment of risks resulting from the procurement of third-party services - Requirements for the classification of third parties - Information security requirements for the processing, storage, or transmission of information by third parties - Requirements for dealing with vulnerabilities, security incidents, and malfunctions - Specifications for the contractual agreement and monitoring of third-party vendor requirements - Requirements for subservice organizations to maintain their own security practices and procedures - Annually reviewing attestation reports for subservice organizations or performing a vendor risk assessment	No exceptions noted.
	Formal policies and procedures that outline the technical and organizational safeguards for change management of system components are documented and include the following components: - Change management roles and responsibilities - Criteria for risk assessment, categorization, and	Inspected the change management procedures to determine that formal policies and procedures that outlined the technical and organizational safeguards for change management of system components were documented and included the following components: - Change management roles and responsibilities	No exceptions noted.

Control Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	prioritization of changes - Approvals for implementation of changes - Requirements for the performance and documentation of tests, including rollback plans - Requirements for segregation of duties during development, testing, and release of changes - Requirements for the implementation and documentation of emergency changes	- Criteria for risk assessment, categorization, and prioritization of changes - Approvals for implementation of changes - Requirements for the performance and documentation of tests, including rollback plans - Requirements for segregation of duties during development, testing, and release of changes - Requirements for the implementation and documentation of emergency changes	
	A formal security and software development life cycle (SDLC) methodology is in place that governs the project planning, design, acquisition, testing, implementation, maintenance, and decommissioning of information systems and related technologies.	Inspected security and SDLC documentation to determine that a formal security and SDLC methodology was in place that governed the project planning, design, acquisition, testing, implementation, maintenance, and decommissioning of information systems and related technologies.	No exceptions noted.
	Network and system hardening standards are documented based on Center for Internet Security (CIS) Benchmarks and reviewed at least annually.	Inspected network and system hardening standards to determine that they were documented based on CIS Benchmarks and reviewed during the period.	No exceptions noted.
	Formal data retention and disposal procedures are documented to guide the secure retention and disposal of Company and customer data.	Inspected the data retention and disposal procedures to determine that data retention and disposal procedures were documented to guide the secure retention and disposal of Company and customer data.	No exceptions noted.

Control Activities			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Policies and procedures derived from the information security policy are documented, version controlled, reviewed at least annually, approved by management, and communicated to authorized users.	Inspected the policies and procedures to determine that policies and procedures derived from the information security policy were documented, version controlled, reviewed during the period, and approved by management.	No exceptions noted.
		Inspected the Company intranet to determine that policies and procedures were communicated to authorized users.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.		
	Remote access to production systems is restricted to authorized employees with valid multi-factor authentication (MFA) tokens over an encrypted virtual private network (VPN) connection.	Inspected system configurations and observed a remote login session to determine that remote access to production systems was restricted to authorized employees with valid MFA tokens over an encrypted VPN connection.	No exceptions noted.
	Authentication to the following in-scope production system components requires unique usernames and passwords or authorized Secure Shell (SSH) keys: - Network - Application - Operating system (OS) - Data stores - Microsoft Azure console - Encryption keys - Firewalls - Log data	Inspected system configurations and observed login attempts to determine that authentication to the following in-scope production system components required unique usernames and passwords or authorized SSH keys: - Network - Application - OS - Data stores - Microsoft Azure console - Encryption keys - Firewalls - Log data	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Passwords for in-scope system components are configured according to the Company's policy, which requires the following (unless there is a system limitation): - Minimum password length of 8 characters, including 2 non-alphanumeric characters - Maximum password age of 90 days for non-privileged accounts and 60 days for privileged accounts - Cannot use last 10 passwords - Lockout threshold of 5 incorrect passwords	Inspected the password policy and password configurations for in-scope system components to determine that passwords were configured according to Company policy, which required the following (unless there was a system limitation): - Minimum password length of 8 characters, including 2 non-alphanumeric characters - Maximum password age of 90 days for non-privileged accounts and 60 days for privileged accounts - Cannot use last 10 passwords - Lockout threshold of 5 incorrect passwords	No exceptions noted.
	Customer accounts with access to the DAX mobile application are configured according to the Company's policy, which requires the following: - Customers are logged out after a period of inactivity and forced to re-authenticate - Customers are required to have a unique personal identification number used for authentication - Lockout threshold of 5 incorrect passwords	Inspected the customer security policy and DAX mobile application configurations to determine customer accounts with access to the DAX mobile application were configured according to Company policy, which required the following: - Customers are logged out after a period of inactivity and forced to re-authenticate - Customers are required to have a unique personal identification number used for authentication - Lockout threshold of 5 incorrect passwords	No exceptions noted.
	The network is segmented to prevent unauthorized access to customer data.	Inspected network configurations to determine that the network was segmented to prevent unauthorized access to customer data.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A formal inventory of production system assets that includes asset owners is maintained, and changes to the inventory are logged.	Inspected the production system asset inventory to determine that a formal inventory of production system assets that included asset owners was maintained and changes to the inventory were logged.	No exceptions noted.
	Encryption is enabled for data stores housing sensitive customer data.	Inspected data store configurations to determine that encryption was enabled for data stores housing sensitive customer data.	No exceptions noted.
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.		
	User access to in-scope system components is based on job role and function and requires a documented access request form and manager approval prior to access being provisioned. The control did not operate during the period because the circumstances that warrant the operation of the control did not occur during the period. No access requests occurred during the period.	Inquired of management and inspected access request documentation to determine that the circumstances that warrant the operation of the control did not occur during the period. As a result, no testing could be performed to determine whether user access to in-scope system components was based on job role and function and required a documented access request form and manager approval prior to access being provisioned.	Not tested. No access requests were identified during the period.
	Termination checklists are completed to track employee terminations, and access is revoked for employees within 24 hours of termination as part of the termination process.	Inspected termination checklists and system access logs for a sample of terminated employees to determine that a termination checklist was completed and logical access was revoked within 24 hours of termination as part of the termination process.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
		Inspected a listing of terminated employees and compared the listing to the active in-scope system access listings to determine that terminated employees did not retain logical access to the in-scope systems after their separation.	No exceptions noted.
	Quarterly access reviews are conducted by management for the in-scope system components to help ensure that access is restricted appropriately.	Inspected access review documentation for a sample of quarters to determine that quarterly access reviews were conducted by management for the in-scope system components to help ensure that access was restricted appropriately.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.		
	Privileged access to the following in-scope production system components is restricted to authorized users with a business need: - Network - Applications - OS - Data stores - Microsoft Azure console - Encryption keys - Firewalls - Log data	Inspected the access listings, inquired of management, and compared each user's level of access to their job role to determine that privileged access to the following in-scope production system components was restricted to authorized users with a business need: - Network - Applications - OS - Data stores - Microsoft Azure console - Encryption keys - Firewalls - Log data	No exceptions noted.
	User access to in-scope system components is based on job role and function and requires a documented access request form and manager approval prior to access being provisioned. The control did not operate during the period because the circumstances that warrant the operation of the control did not occur during the period. No access requests occurred during the period.	Inquired of management and inspected access request documentation to determine that the circumstances that warrant the operation of the control did not occur during the period. As a result, no testing could be performed to determine whether user access to in-scope system components was based on job role and function and required a documented access request form and manager approval prior to access being provisioned.	Not tested. No access requests were identified during the period.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Termination checklists are completed to track employee terminations, and access is revoked for employees within 24 hours of termination as part of the termination process.	Inspected termination checklists and system access logs for a sample of terminated employees to determine that a termination checklist was completed and logical access was revoked within 24 hours of termination as part of the termination process.	No exceptions noted.
		Inspected a listing of terminated employees and compared the listing to the active in-scope system access listings to determine that terminated employees did not retain logical access to the in-scope systems after their separation.	No exceptions noted.
	Quarterly access reviews are conducted by management for the in-scope system components to help ensure that access is restricted appropriately.	Inspected access review documentation for a sample of quarters to determine that quarterly access reviews were conducted by management for the in-scope system components to help ensure that access was restricted appropriately.	No exceptions noted.
	Access to migrate changes to production is restricted to authorized personnel. Developers must have changes reviewed prior to migration in production.	Inspected system access listings, inquired of management, and compared each user's level of access to their job role to determine that access to migrate changes to production was restricted to authorized personnel.	No exceptions noted.
		Inspected system configurations to determine that developers were required to have changes reviewed prior to migration in production.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Service account login credentials are stored in a password manager, and access to the credentials is restricted to authorized users with a business need.	Inspected the password management tool to determine that service account login credentials were stored in a password manager.	No exceptions noted.
		Inspected the access listings, inquired of management, and compared each user's level of access to their job role to determine that access to the service account login credentials was restricted to authorized users with a business need.	No exceptions noted.
CC6.4	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.		
	The Company's production environment is hosted at Microsoft Azure and third-party data centers, which are carved out for the purposes of this report.	Not applicable.	Not applicable.
CC6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A formal inventory of production system assets that includes asset owners is maintained, and changes to the inventory are logged.	Inspected the production system asset inventory to determine that a formal inventory of production system assets that included asset owners was maintained and changes to the inventory were logged.	No exceptions noted.
	Formal data retention and disposal procedures are documented to guide the secure retention and disposal of Company and customer data.	Inspected the data retention and disposal procedures to determine that data retention and disposal procedures were documented to guide the secure retention and disposal of Company and customer data.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.		
	Remote access to production systems is restricted to authorized employees with valid multi-factor authentication (MFA) tokens over an encrypted virtual private network (VPN) connection.	Inspected system configurations and observed a remote login session to determine that remote access to production systems was restricted to authorized employees with valid MFA tokens over an encrypted VPN connection.	No exceptions noted.
	Firewalls and security groups are used and configured to prevent unauthorized access to the production environment.	Inspected firewall configurations and security groups to determine that firewalls and security groups were used and configured to prevent unauthorized access to the production environment.	No exceptions noted.
	A web application firewall (WAF) is used and configured to prevent unauthorized access to the production environment.	Inspected WAF configurations to determine that a WAF was used and configured to prevent unauthorized access to the production environment.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Firewall rulesets and security groups are reviewed at least annually. Change tickets are created to track any firewall modifications as a result of the review.	Inspected the firewall and security group review documentation to determine that firewall rulesets and security groups were reviewed during the period.	No exceptions noted.
		Inspected change tickets for a sample of changes that resulted from the firewall ruleset and security group review to determine that change tickets were created to track firewall modifications resulting from the review.	No exceptions noted.
	Secure data transmission protocols are used to encrypt confidential and sensitive data when transmitted over public networks.	Inspected transmission protocol configurations to determine that secure data transmission protocols were used to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.
	An intrusion detection system (IDS) and intrusion prevention system (IPS) are used to provide continuous monitoring of the Company's network and early detection and prevention of potential security breaches. Alerts are configured to notify administrators to investigate and take appropriate action based on the severity of the alert.	Inspected IDS and IPS configurations to determine that an IDS and IPS were used to provide continuous monitoring of the Company's network and early detection and prevention of potential security breaches.	No exceptions noted.
		Inspected IDS and IPS alert configurations and example alerts to determine that alerts were configured to notify administrators of detected and prevented potential security breaches for investigation and resolution.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Infrastructure supporting the service is patched as a part of routine maintenance and as a result of identified vulnerabilities to help ensure that servers supporting the service are hardened against security threats.	Inspected a sample of patches to the production environment to determine that infrastructure supporting the service was patched as a part of routine maintenance and as a result of identified vulnerabilities.	No exceptions noted.
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.
	Secure data transmission protocols are used to encrypt confidential and sensitive data when transmitted over public networks.	Inspected transmission protocol configurations to determine that secure data transmission protocols were used to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.
CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.		
	Anti-malware technology is deployed for environments commonly susceptible to malicious attack and is configured to be updated routinely, logged, and installed on all relevant production servers and endpoints.	Inspected anti-malware software configurations to determine that anti-malware technology was deployed for environments commonly susceptible to malicious attack and was configured to be updated routinely, logged, and installed on all relevant production servers and endpoints.	No exceptions noted.

Logical and Physical Access Controls			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	An intrusion detection system (IDS) and intrusion prevention system (IPS) are used to provide continuous monitoring of the Company's network and early detection and prevention of potential security breaches. Alerts are configured to notify administrators to investigate and take appropriate action based on the severity of the alert.	Inspected IDS and IPS configurations to determine that an IDS and IPS were used to provide continuous monitoring of the Company's network and early detection and prevention of potential security breaches.	No exceptions noted.
		Inspected IDS and IPS alert configurations and example alerts to determine that alerts were configured to notify administrators of detected and prevented potential security breaches for investigation and resolution.	No exceptions noted.
	Infrastructure supporting the service is patched as a part of routine maintenance and as a result of identified vulnerabilities to help ensure that servers supporting the service are hardened against security threats.	Inspected a sample of patches to the production environment to determine that infrastructure supporting the service was patched as a part of routine maintenance and as a result of identified vulnerabilities.	No exceptions noted.

System Operations			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.		
	Internal and external network vulnerability scans are performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	Inspected internal and external network vulnerability scans for a sample of quarters to determine that internal and external network vulnerability scans were performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	No exceptions noted.
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during quarterly internal and external network vulnerability scans.	Inspected remediation plans for vulnerabilities identified during the sampled quarterly internal and external network vulnerability scans to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the scans.	No exceptions noted.
	A risk assessment is performed at least annually. As part of this process, threats and changes to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected risk assessment documentation to determine that a risk assessment was performed during the period and that, as part of this process, threats and changes to service commitments were identified and the risks were formally assessed.	No exceptions noted.
		Inspected risk assessment documentation to determine that the risk assessment included a consideration of the potential for fraud and how fraud may have impacted the achievement of objectives.	No exceptions noted.

System Operations			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A configuration management tool (CMT) is in place to ensure that system configurations are deployed consistently throughout the environment.	Inspected CMT configurations to determine that a CMT was in place to ensure that system configurations were deployed consistently throughout the environment.	No exceptions noted.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.		
	A log management tool is utilized to identify trends that may have a potential impact on the Company's ability to achieve its security objectives and generates alerts when specific events occur.	Inspected the log management tool configurations to determine that a log management tool was utilized to identify trends that may have had a potential impact on the Company's ability to achieve its security objectives and generated alerts when specific events occurred.	No exceptions noted.
	Internal and external network vulnerability scans are performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	Inspected internal and external network vulnerability scans for a sample of quarters to determine that internal and external network vulnerability scans were performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	No exceptions noted.
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during quarterly internal and external network vulnerability scans.	Inspected remediation plans for vulnerabilities identified during the sampled quarterly internal and external network vulnerability scans to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the scans.	No exceptions noted.

System Operations			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	An intrusion detection system (IDS) and intrusion prevention system (IPS) are used to provide continuous monitoring of the Company's network and early detection and prevention of potential security breaches. Alerts are configured to notify administrators to investigate and take appropriate action based on the severity of the alert.	Inspected IDS and IPS configurations to determine that an IDS and IPS were used to provide continuous monitoring of the Company's network and early detection and prevention of potential security breaches.	No exceptions noted.
		Inspected IDS and IPS alert configurations and example alerts to determine that alerts were configured to notify administrators of detected and prevented potential security breaches for investigation and resolution.	No exceptions noted.
	An infrastructure monitoring tool is utilized to monitor system or infrastructure availability and performance and generates alerts when specific, predefined thresholds are met.	Inspected the infrastructure monitoring tool configurations and example alerts to determine that an infrastructure monitoring tool was utilized to monitor system or infrastructure availability and performance and generated alerts when specific, predefined thresholds were met.	No exceptions noted.
	Penetration testing is performed at least annually to identify vulnerabilities that could be exploited to gain access to the production environment.	Inspected the penetration test report to determine that penetration testing was performed during the period to identify vulnerabilities that could have been exploited to gain access to the production environment.	No exceptions noted.

System Operations			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during the annual penetration test.	Inspected remediation plans for vulnerabilities identified during the annual penetration test to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the annual penetration test.	No exceptions noted.
	Infrastructure supporting the service is patched as a part of routine maintenance and as a result of identified vulnerabilities to help ensure that servers supporting the service are hardened against security threats.	Inspected a sample of patches to the production environment to determine that infrastructure supporting the service was patched as a part of routine maintenance and as a result of identified vulnerabilities.	No exceptions noted.
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.		
	Security incident response policies and procedures are documented and provide guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	Inspected the security incident response policies and procedures to determine that they were documented and provided guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
	Security events are logged, tracked, resolved, and communicated to affected parties by management according to the Company's security incident response policies and procedures. All events are evaluated to determine whether they could have resulted in a failure to meet security commitments and objectives.	Inspected a sample of security event tickets to determine that security events were logged, tracked, resolved, evaluated to determine whether they could have resulted in a failure to meet security commitments and objectives, and communicated to affected parties by management according to the Company's security incident response policies and procedures.	No exceptions noted.

System Operations			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Penetration testing is performed at least annually to identify vulnerabilities that could be exploited to gain access to the production environment.	Inspected the penetration test report to determine that penetration testing was performed during the period to identify vulnerabilities that could have been exploited to gain access to the production environment.	No exceptions noted.
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during the annual penetration test.	Inspected remediation plans for vulnerabilities identified during the annual penetration test to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the annual penetration test.	No exceptions noted.
	Internal and external network vulnerability scans are performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	Inspected internal and external network vulnerability scans for a sample of quarters to determine that internal and external network vulnerability scans were performed at least quarterly to identify, quantify, and prioritize vulnerabilities.	No exceptions noted.
	A remediation plan is developed and changes are implemented to remediate, at a minimum, all critical and high vulnerabilities identified during quarterly internal and external network vulnerability scans.	Inspected remediation plans for vulnerabilities identified during the sampled quarterly internal and external network vulnerability scans to determine that remediation plans were developed and changes were implemented to remediate all critical and high vulnerabilities identified during the scans.	No exceptions noted.

System Operations			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
	Infrastructure supporting the service is patched as a part of routine maintenance and as a result of identified vulnerabilities to help ensure that servers supporting the service are hardened against security threats.	Inspected a sample of patches to the production environment to determine that infrastructure supporting the service was patched as a part of routine maintenance and as a result of identified vulnerabilities.	No exceptions noted.
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.		
	Security incident response policies and procedures are documented and provide guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	Inspected the security incident response policies and procedures to determine that they were documented and provided guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
	All incidents related to security are logged, tracked, evaluated, and communicated to affected parties by management until the Company has recovered from the incidents. The control did not operate during the period because the circumstances that warrant the operation of the control did not occur during the period. No security incidents occurred during the period.	Inquired of management and inspected security event documentation to determine that the circumstances that warrant the operation of the control did not occur during the period. As a result, no testing could be performed to determine whether all incidents related to security were logged, tracked, evaluated, and communicated to affected parties by management until the Company had recovered from the incidents.	Not tested. No security incidents were identified during the period.

System Operations			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.		
	Security incident response policies and procedures are documented and provide guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	Inspected the security incident response policies and procedures to determine that they were documented and provided guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
	All incidents related to security are logged, tracked, evaluated, and communicated to affected parties by management until the Company has recovered from the incidents. The control did not operate during the period because the circumstances that warrant the operation of the control did not occur during the period. No security incidents occurred during the period.	Inquired of management and inspected security event documentation to determine that the circumstances that warrant the operation of the control did not occur during the period. As a result, no testing could be performed to determine whether all incidents related to security were logged, tracked, evaluated, and communicated to affected parties by management until the Company had recovered from the incidents.	Not tested. No security incidents were identified during the period.
	The incident response plan is tested at least annually to assess the effectiveness of the incident response program.	Inspected the incident response plan test results to determine that the incident response plan was tested during the period to assess the effectiveness of the incident response program.	No exceptions noted.

Change Management			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.		
	Changes to software and infrastructure components of the service are authorized, formally documented, tested, reviewed, and approved prior to being implemented in the production environment.	Inspected change request tickets for a sample of software and infrastructure changes to determine that software and infrastructure changes were authorized, formally documented, tested, reviewed, and approved prior to being implemented in the production environment.	No exceptions noted.
	Access to migrate changes to production is restricted to authorized personnel. Developers must have changes reviewed prior to migration in production.	Inspected system access listings, inquired of management, and compared each user's level of access to their job role to determine that access to migrate changes to production was restricted to authorized personnel.	No exceptions noted.
		Inspected system configurations to determine that developers were required to have changes reviewed prior to migration in production.	No exceptions noted.
	Infrastructure supporting the service is patched as a part of routine maintenance and as a result of identified vulnerabilities to help ensure that servers supporting the service are hardened against security threats.	Inspected a sample of patches to the production environment to determine that infrastructure supporting the service was patched as a part of routine maintenance and as a result of identified vulnerabilities.	No exceptions noted.

Risk Mitigation			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.		
	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
	Security incident response policies and procedures are documented and provide guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	Inspected the security incident response policies and procedures to determine that they were documented and provided guidance to Company personnel for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
	The incident response plan is tested at least annually to assess the effectiveness of the incident response program.	Inspected the incident response plan test results to determine that the incident response plan was tested during the period to assess the effectiveness of the incident response program.	No exceptions noted.
CC9.2	The entity assesses and manages risks associated with vendors and business partners.		
	Vendor risk assessments that include attestation report reviews are performed at least annually for all subservice organizations to evaluate the impact of noted exceptions on the service.	Inspected vendor risk assessment documentation for all subservice organizations to determine that vendor risk assessments that included attestation report reviews were performed during the period for all subservice organizations to evaluate the impact of noted exceptions on the service.	No exceptions noted.

Additional Criteria for Confidentiality

Confidentiality			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
C1.1	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.		
	A data classification policy is documented to help ensure that confidential data is properly secured and restricted to authorized personnel.	Inspected the data classification policy to determine that a data classification policy was documented to help ensure that confidential data was properly secured and restricted to authorized personnel.	No exceptions noted.
	Confidential or sensitive customer data is prohibited by policy from being used or stored in non-production systems or environments.	Inspected the data classification policy to determine that confidential or sensitive customer data was prohibited by policy from being used or stored in non-production systems or environments.	No exceptions noted.
		Observed the test environment to determine that only test data was used in non-production systems or environments.	No exceptions noted.
	Formal data retention and disposal procedures are documented to guide the secure retention and disposal of Company and customer data.	Inspected the data retention and disposal procedures to determine that data retention and disposal procedures were documented to guide the secure retention and disposal of Company and customer data.	No exceptions noted.

Confidentiality			
TSC Reference	Trust Services Criteria and Applicable Control Activities	Service Auditor's Tests	Results of Tests
C1.2	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.		
	Elements of the Company's control environment are performed by Microsoft Azure, which are carved out for the purposes of this report. Please see complementary corporate-level controls in Section 3 of this report.	Not applicable.	Not applicable.
	Customer data in the application, metadata, and data stored in data backups are deleted when customers leave the service in accordance with contractual agreements.	Inspected tickets for data removal or purging for a sample of customers who left the service to determine that customer data in the application, metadata, and data stored in data backups were deleted when customers left the service in accordance with contractual agreements.	No exceptions noted.